



Politécnico
Internacional

FUNDAMENTOS DE CIBERSEGURIDAD

Cybersecurity Nexus

HAROL HERNAN TORRES NEUTA

Mg. Ed en Tecnología

Esp. Seguridad Informática



Harol Hernán Torres Neuta
Magister en Educación en Tecnología
Licenciado en Informática

Temas de Curso



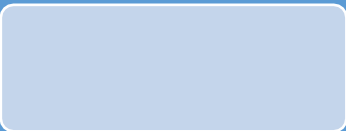
1. INTRODUCCIÓN Y VISIÓN GENERAL DE LA CIBERSEGURIDAD



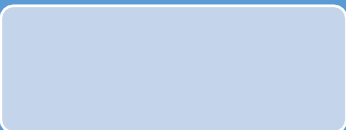
2. CONCEPTOS DE LA CIBERSEGURIDAD



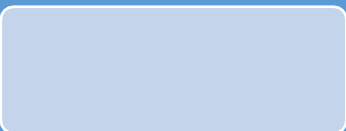
3. PRINCIPIOS DE ARQUITECTURA DE SEGURIDAD



4. SEGURIDAD DE REDES, SISTEMAS, APLICACIONES Y DATOS

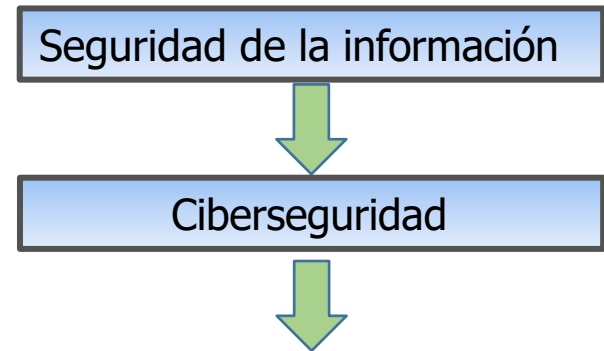


5. RESPUESTA A INCIDENTES



6. IMPLICACIONES DE SEGURIDAD Y ADOPCIÓN DE LA TECNOLOGÍA

Protección de la información:



Protección de los activos de información, abordando las amenazas a la información **procesada**, **almacenada** y **transportada** por sistemas interconectados.

Desafíos

Ciberseguridad y Concienciación Situacional

- Nuevas tendencias en movilidad y conectividad
- Desarrollo de nuevos ataques – tecnologías emergentes.
- APTs

Conciencia Situacional

Factores comerciales y tecnológicos (interno y externo).

- ☐ Planes de negocio y entorno empresarial
- ☐ Tecnologías de información disponibles

Brechas

Contar con personal expertos en tecnología, negocios y comunicación

Tecnologías de información disponibles

Factores:

- ☐ Plataformas y herramientas
- ☐ Conectividad
- ☐ Nivel de complejidad de TI
- ☐ Apoyo operativo
- ☐ Comunidad de usuarios y capacidades
- ☐ Herramientas de seguridad

Planes de negocio y entorno empresarial

Variables:

- ☐ Naturaleza del negocio
- ☐ Tolerancia al riesgo
- ☐ Perfil de seguridad
- ☐ Tendencias de la industria
- ☐ Fusiones, adquisiciones y alianzas
- ☐ Tipo, frecuencia y nivel resultante de la integración
- ☐ Servicios externalizados o proveedores

Seguridad de la Información -> Maneja cualquier tipo de información:

- ☐ Documentos físicos
- ☐ Propiedad digital e intelectual
- ☐ Comunicaciones verbales o visuales.

Ciberseguridad -> Protección de activos digitales:

- ❖ Redes
- ❖ Hardware
- ❖ Información procesada, almacenada o transportada a través los sistemas interconectados.

**PROTECCIÓN DE
ACTIVOS DIGITALES**

Identificar

Proteger

Detectar

Responder

Recuperar



Requerimiento	Impacto y Consecuencias Potenciales	Métodos de control
Confidencialidad	❖ Divulgación de información ❖ Pérdida de confianza ❖ Ventaja competitiva ❖ Interferencia con la seguridad nacional	◆ Controles de acceso ◆ Permisos de archivos ◆ Cifrado
Integridad	❖ Imprecisión ❖ Decisiones erróneas ❖ Fraude	◆ Controles de acceso ◆ Registros de acceso ◆ Firmas digitales ◆ Cifrado
Disponibilidad	❖ Pérdida de funcionalidad ❖ Pérdida de tiempo	◆ Redundancia ◆ Copias de seguridad ◆ Controles de acceso

Gobierno

Roles de la Ciberseguridad

- Proporcionar orientación estratégica.
- Asegurar que se cumplan los objetivos.
- Determinar si el riesgo se está gestionando apropiadamente.
- Verificar que los recursos de la organización se están utilizando de manera responsable.

GRC=> Governance, Risk and Compliance

Cada organización tiene su propia misión de negocio, cultura y normas legales.

Gestión del riesgo

- Gestionar riesgos a niveles aceptables.
- Desarrollar e implementar controles para gestionar y mitigar riesgos de tipo financiero, de inversión, físico y ciber riesgo.

Cumplimiento

- Adhesión a requisitos definidos en leyes y regulaciones.

¿Qué hace el profesional de Ciberseguridad

- ☐ Análisis de políticas, tendencias e inteligencia.
- ☐ Habilidades de detección: Comprender mejor como un adversario puede pensar o comportarse.
- ☐ Capacidades analíticas avanzadas.

COMITÉ DE DIRECCIÓN

- ☐ Un gobierno eficaz sólo puede lograrse mediante la participación de la alta dirección.
- ☐ Presentación de informes.
- ☐ Análisis de tendencias.
- ☐ Los miembros del concejo necesitan ser conscientes de los activos de información con el fin de identificar los procesos esenciales de negocio. A través de la evaluación de riesgos y un análisis de impacto de negocio (BIA) se establecerán los niveles de protección y prioridades apropiadas.

Dirección ejecutiva

- ❖ Asegura que las funciones organizacionales, recursos e infraestructura de apoyo, estén disponibles y se utilizarán adecuadamente para cumplir con las directrices de la junta directiva.
- ❖ Definición del programa de seguridad de la información (CISO o gerente de ciberseguridad).
- ❖ El gestor de seguridad actúa como consultor.
- ❖ Establece el tono para la gestión de la ciberseguridad dentro de la organización.



Gerente de Seguridad de la Información

Es responsable de:

- ☐ Desarrollar la estrategia de seguridad.
- ☐ Supervisar el programa y las iniciativas de seguridad.
- ☐ Coordinar con los propietarios de los procesos de negocio para mantener una alineación continua.
- ☐ Asegurar que las evaluaciones de riesgo y de impacto del negocio se lleven a cabo.
- ☐ Desarrollar estrategias de mitigación de riesgo.
- ☐ Hacer cumplir las políticas y el cumplimiento normativo.
- ☐ Monitorear la utilización y eficacia de los recursos de seguridad.
- ☐ Desarrollar e implementar métricas y monitoreo.
- ☐ Dirigir y monitorear actividades de seguridad.
- ☐ Gestionar incidentes de ciberseguridad y su solución, incorporando las lecciones aprendidas.



Dominios de la Ciberseguridad

1. Conceptos de ciberseguridad.
2. Principios de arquitectura de seguridad.
3. Seguridad de redes, sistemas, aplicaciones y datos.
4. Respuesta a Incidentes.
5. Implicaciones de seguridad y la adopción de tecnología en evolución.

1. Conceptos de Ciberseguridad

- Gestión básica de riesgos
- Vectores comunes de ataque y agentes de amenazas
- Patrones y tipos de ataques
- Tipos de políticas y procedimientos de seguridad
- Procesos de control de ciberseguridad



2. Principios de arquitectura de Seguridad

- ❑ Arquitectura e infraestructura de seguridad y marcos de trabajo.
- ❑ Topología del sistema.
- ❑ Firewall y cifrado.
- ❑ Aislamiento y segmentación.
- ❑ Métodos de monitoreo.



3. Seguridad de redes, sistemas, aplicaciones y datos

- Controles de Proceso

- Evaluaciones de riesgos
- Gestión de vulnerabilidad
- Pruebas de penetración



- Mejores prácticas

- Amenazas y vulnerabilidades de seguridad en sistemas y aplicaciones
- Controles eficaces para la gestión de vulnerabilidades

4. Respuesta a Incidentes

Distinción fundamental entre un evento y un incidente.



- ❖ Categorías de incidentes.
- ❖ Planes recuperación de desastres y de continuidad del negocio **DRP – BCP.**
- ❖ Pasos de respuesta a incidentes.
- ❖ Ciencia forense y preservación de las pruebas.

5. Implicaciones de Seguridad y adopción de tecnología en evolución

- ☐ Dispositivos móviles
- ☐ Cómputo y almacenamiento en la nube
- ☐ Colaboración digital
- ☐ BYOD
- ☐ Aplicaciones web
- ☐ APTs



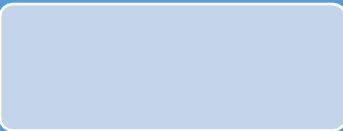
Temas del Curso



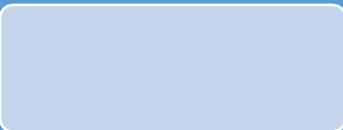
1. INTRODUCCIÓN Y VISIÓN GENERAL DE LA CIBERSEGURIDAD



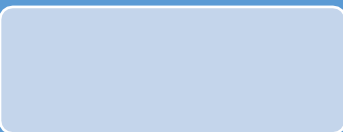
2. CONCEPTOS DE LA CIBERSEGURIDAD



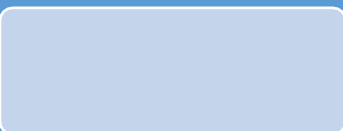
3. PRINCIPIOS DE ARQUITECTURA DE SEGURIDAD



4. SEGURIDAD DE REDES, SISTEMAS, APLICACIONES Y DATOS



5. RESPUESTA A INCIDENTES



6. IMPLICACIONES DE SEGURIDAD Y ADOPCIÓN DE LA TECNOLOGÍA

Riesgo

Deber principal de la ciberseguridad: Identificar, mitigar y gestionar el ciberriesgo.

Riesgo en el contexto de la ciberseguridad: Determinar, medir y reducir el riesgo de forma efectiva.

Evaluación del riesgo: Utilizar un enfoque basado en el riesgo permite la toma de decisiones aplicando los presupuestos y los recursos limitados de manera efectiva.

Los controles deben ser aplicados de acuerdo al conocimiento de los riesgos reales.

Enfoques en Ciberseguridad

Basado en cumplimiento: Estándares - **Herramienta:** Lista de control

Basado en riesgos: identificar el riesgo único al que una organización se enfrenta, definirá el diseño e implementación de controles de seguridad para hacer frente al riesgo por encima y más allá de la tolerancia al riesgo.

Ad hoc: Implementa seguridad sin fundamento.
Impulsadas por la comercialización del proveedor, o por experiencia insuficiente.

La mayoría de las organizaciones utilizan una combinación de enfoques basados en riesgos y basados en cumplimiento.



Conceptos

Riesgo: Combinación de la probabilidad de un evento y sus consecuencias. El riesgo se mitiga con el uso de controles.

Amenaza: Cualquier cosa que es capaz de actuar en contra de un activo.

Activos: Algo de valor ya sea tangible o intangible.

Incluye: Personas, información, infraestructura, finanzas, reputación.

Vulnerabilidad: Debilidad que podría exponer a un sistema a eventos de amenaza.

Riesgo Residual: Riesgo que permanece después de haberse implementado una respuesta al riesgo

Riesgo Inherente: Nivel de riesgo donde no se han tomado acciones referente al riesgo identificado.

Probabilidad: Datos, probabilidad matemática

Impacto: Magnitud del daño. Pueden ser de forma cualitativa o cuantitativa. Para el caso de ciberseguridad, se evalúa en términos de confidencialidad, disponibilidad e integridad.

Enfoques de Riesgo

CRITERIOS.

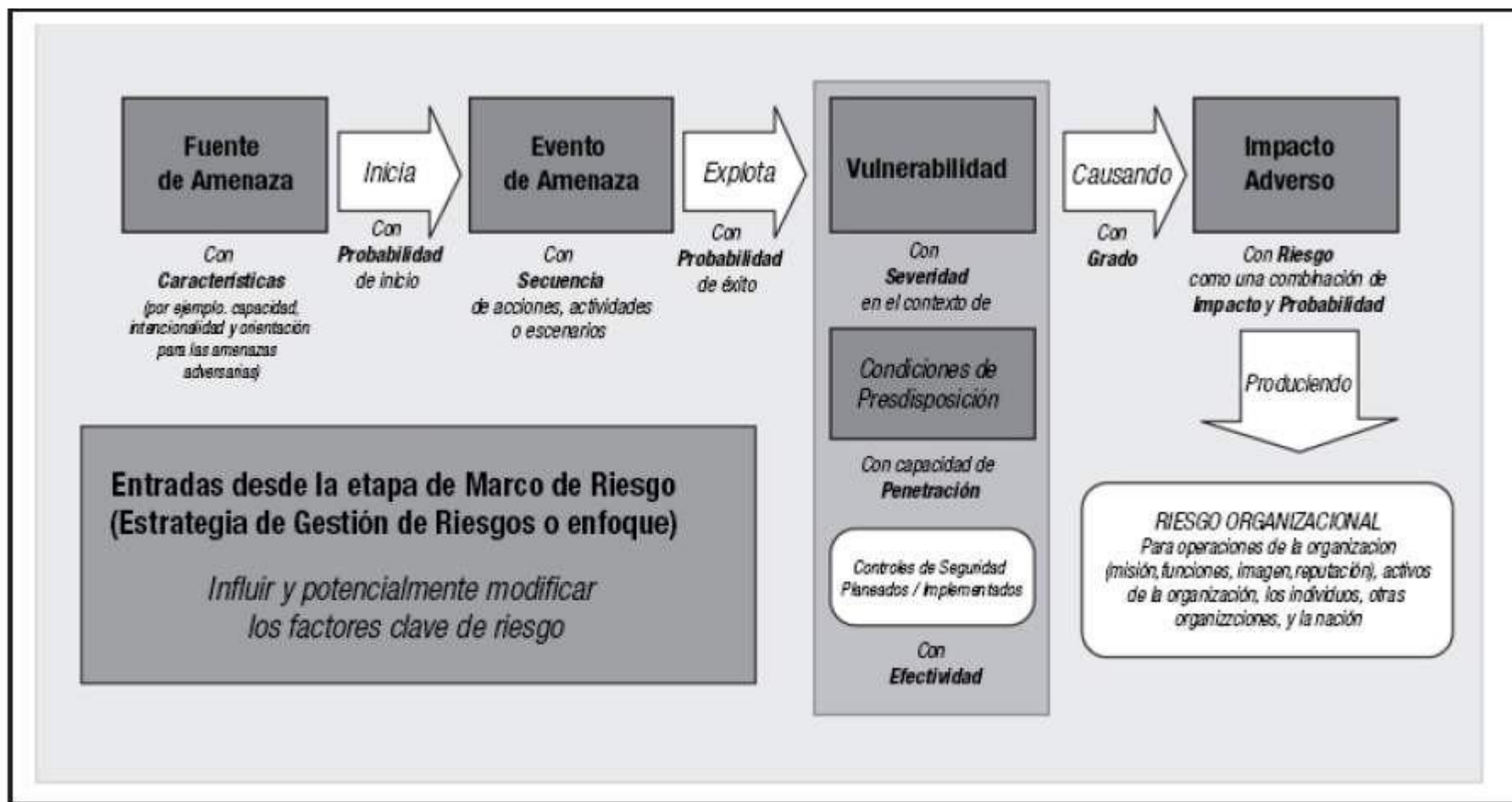
- ☐ Tolerancia al riesgo
- ☐ Tamaño y ámbito del medio ambiente en cuestión
- ☐ Cantidad de datos disponibles

Nota: se requiere de una evaluación de riesgos más rigurosa y de mayor profundidad para entidades con una baja tolerancia al riesgo.

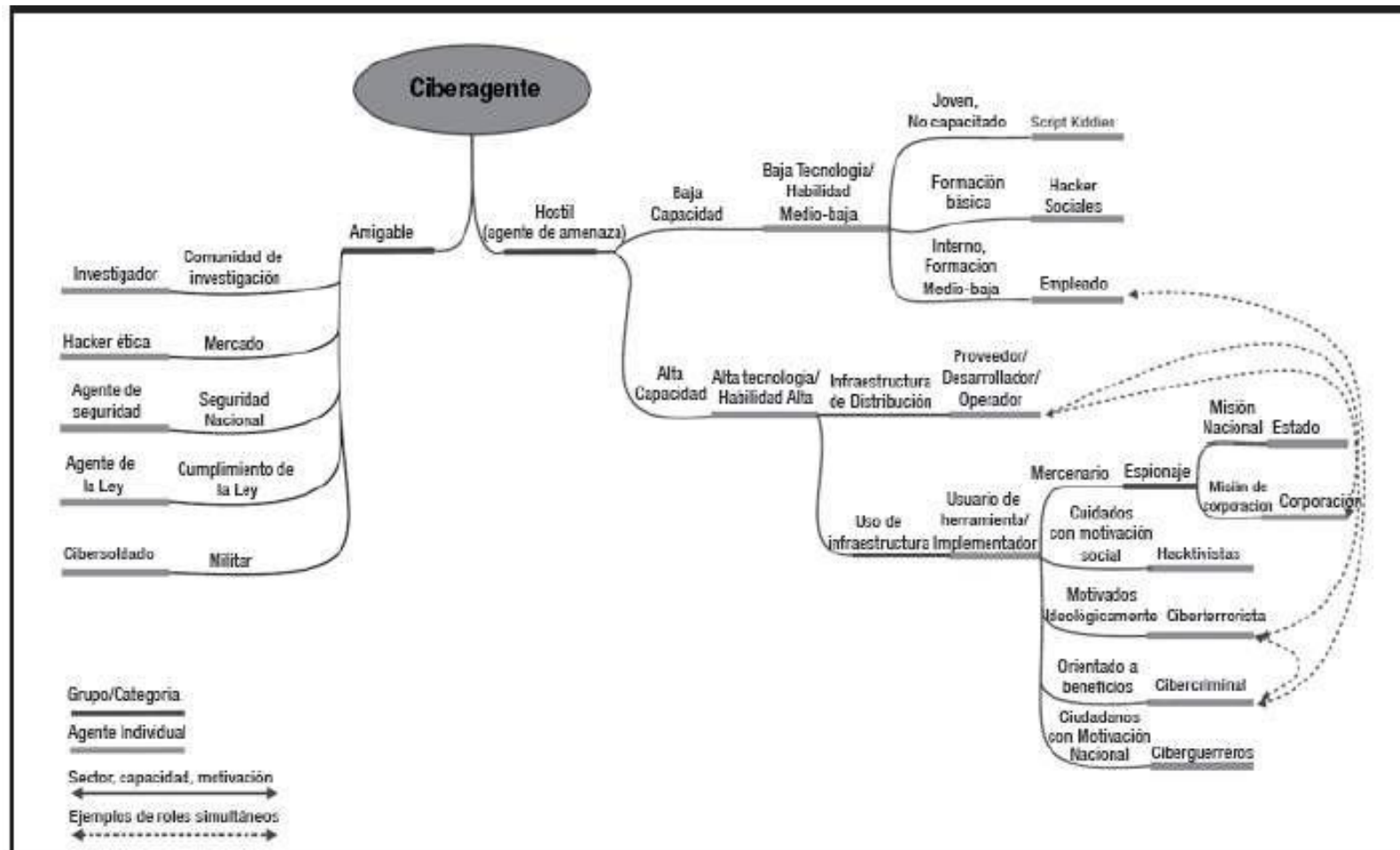
RIESGO DE TERCEROS

Los riesgos pueden ser más difícil de controlar cuando hay terceros involucrados.

Es **importante** entender los riesgos de terceros(intercambio de información, acceso a la red).



un **ciberataque** es un ataque bien definido, avanzado, dirigido que es sigiloso y que tiene una misión que no va a dejar de intentar lograr hasta que sea identificado y mitigado o bien tenga éxito.



Agentes de Amenaza.

Corporaciones => Rompen los límites de seguridad para realizar actos maliciosos y obtener una ventaja competitiva.

Estados nacionales => Focalizadas en gobiernos y entidades privadas para obtener inteligencia.

Hacktivistas => Pueden actuar de forma independiente. Objetivo: Personas u organizaciones.

Ciber terroristas => Usan la violencia para lograr sus objetivos (infraestructuras críticas y grupos gubernamentales).

Cibercriminales => Motivados por el afán de lucro; involucrados en transacciones financieras fraudulentas.

Agentes de Amenaza.

Ciberguerreros => Conocidos como cibercombatiente; ciudadanos motivados a nivel nacional que pueden actuar en nombre de un partido político o en contra de otro partido político que los amenaza.

Script Kiddies => Personas jóvenes que están aprendiendo a hackear; involucrados principalmente en inyecciones de código y los ataques (DDoS).

Hackers Sociales —Cualificados en la ingeniería social; frecuentemente implicados en el ciberacoso, robo de identidad y la recolección de otra información confidencial.

Empleados => Métodos y herramientas de bajo nivel tecnológico; representan un riesgo de ciberseguridad clara. Todos estos ataques son conflictivos.

Atributos del Ataque.



Evento de amenaza: Con confrontación o sin confrontación.

Ataque: Actividad realizada por un agente de amenaza contra un activo.

Vector de ataque: Camino o ruta para acceder al activo. Puede ser de entrada o salida.

Payload: Mecanismo de ataque o el método utilizado para entregar el exploit.

Exploit: Código para explotar vulnerabilidades.



1. Realizar reconocimiento

- ❖ Sniffing
- ❖ Uso de información de la organización de libre acceso
- ❖ Malware

2. Crear herramientas de ataque

- ☐ Phishing
- ☐ Sitios web o certificados fraudulentos
- ☐ Falsas organizaciones

3. Entrega de funciones maliciosas

- Introducción de malware
- Colocación de individuos subvertidos (insiders)
- Sniffers o dispositivos de escaneo en redes y sistemas objetivo
- Introducir hardware o componentes críticos manipulados en los sistemas de organización

Proceso de Ataque Generalizado.

4. Explotar vulnerabilidades y comprometer

- ❖ Split tunneling o conseguir acceso físico
- ❖ Abuso de la capacidad en la nube
- ❖ Exploits de día cero
- ❖ Exfiltración de datos

5. Dirigir un ataque

- ☐ Interceptación de comunicaciones
- ☐ Ataques de denegación de servicio (DoS) o (DDoS)
- ☐ Interferencias a distancia o ataques físicos
- ☐ ataque MiTM



Proceso de Ataque Generalizado.

6. Obtención de resultados

- ❖ Acceso no autorizado
- ❖ Degradación de servicios
- ❖ Crear, corromper o borrar datos críticos

7. Mantener una presencia

- ☐ interferencia con los sistemas de detección de intrusos (IDS)
- ☐ Adaptación de los ciberataques en respuesta a las medidas de seguridad

8. Coordinar una campaña

- Ataques de múltiples etapas
- Ataques internos y externos
- Ataques generalizados y adaptados

- Mal manejo de la información
- Privilegios asignados de forma incorrecta
- Incendio, inundación, huracanes, tormentas o terremotos
- Vulnerabilidades en productos de software
- Errores genéricos causados por la antigüedad de los equipos

Eventos de Amenaza.

MALWARE Y TIPOS DE ATAQUE

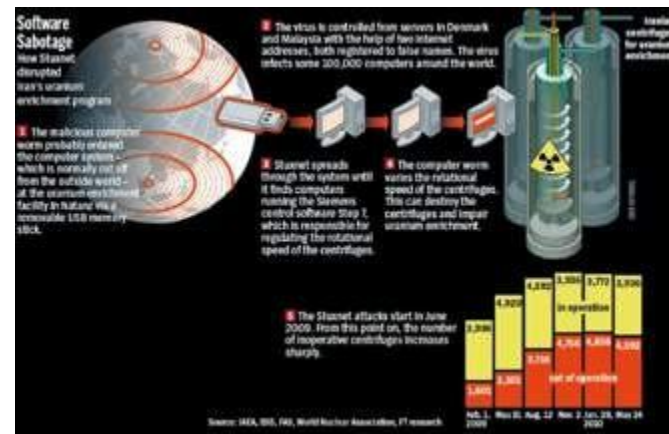
Código malicioso, que tiene como finalidad tener acceso a sistemas informáticos específicos, robar información o interrumpir las operaciones informáticas. Tipos de malware más importantes: virus informáticos, gusanos y troyanos.

Herramienta de ciberespionaje: Flamer y Skywiper – Registra actividad del teclado, tráfico de red, captura de pantalla, envía la información a varios servidores y con un "kill command" elimina el rastro de malware sobre el dispositivo.

Stuxnet: Utilizado para comprometer los sistemas:

Componentes

1. Un gusano
2. Un link
3. Un rootkit



Otros tipos de Ataque.

- **Virus** => Código que busca replicarse a si mismo de un ordenador a otro. **Requiere intervención de usuario para ejecutarlo.**
- **Gusano** => Variante de virus informático. Objetivo: Replicarse a través de las redes. **No requiere intervención para su replicación.**
- **Troyano** => Obtiene acceso a un sistema ocultándose dentro de una aplicación real.
- **Botnet** => «Robot network». Red grande computarizada, automatizada y distribuida controlados simultáneamente para lanzar **ataques a gran escala.**
- **Spyware** => Recopila información sin el conocimiento por parte del usuario y/o corporación.
- **Adware** => Mostrar anuncios (generalmente no deseados).
- **Ransomware** => Malware de extorsión. Objetivo: Codifica los datos para exigir pago para su recuperación.
- **Keylogger** => Registra de manera oculta las pulsaciones de teclado o contenido de la pantalla.
- **Rootkit** => Oculta la existencia de otro tipo malware mediante la modificación del S.O

Otros tipos de Ataque.

MITRE — Catalogo de patrones de ataque (**CAPEC**) - Enumeración de patrones de ataque común

Patrones de Ataque comunes:

Amenazas persistentes avanzadas — Ataques complejos, coordinados y dirigidos.

Puerta trasera — Medio de recuperar el acceso a un sistema comprometido.

Ataque de fuerza bruta — Intenta todas las combinaciones posibles de contraseñas.
Desbordamiento de buffer (Buffer overflow)— Programa o proceso que intenta almacenar más datos en un buffer de lo que puede mantener.

Cross-site scripting (XSS) — Inyección en el que un script malicioso se inyecta en los sitios web benignos y de confianza.

Ataque de denegación de servicio (DoS) — inundación con un número alto de solicitudes que no puede manejar causando colapsar el sitio web u otros servicios.



Patrones de Ataque Comunes.

Ataque de MiTM —Intercepta el flujo de comunicación entre dos partes de un sistema victima, con el fin de asumir el control de la comunicación.

Ingeniería social — Explotar vulnerabilidades sociales.

Phishing — Ataque vía correo electrónico (e-mail) que tiene la intención de obtener información para su uso en un ataque.

Phishing de ingeniería social (Spear phishing) —Ataque donde se utilizan técnicas de ingeniería social para hacerse pasar por una entidad de confianza.

Spoofing—Falsificación de una dirección de envío de una transmisión

Inyección de SQL — Resultante de un fallo en una aplicación a nivel del input.

Exploit de día cero — Vulnerabilidad que se explota antes de que el creador/proveedor del software sea consciente de su existencia.

Deben crearse, aceptarse y validarse por la junta directiva y la gerencia ejecutiva antes de ser comunicadas en toda la organización.

CICLO DE VIDA DE LAS POLÍTICAS



Cada documento debe tener un proceso formal para ser creado, revisado, actualizado y aprobado. Además, puede haber la necesidad legítima de una excepción a la política.

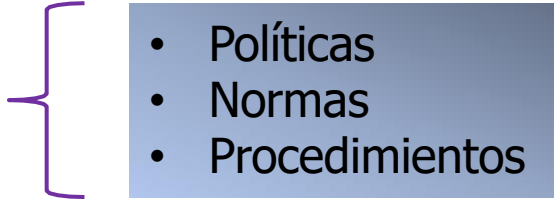
Es necesario un proceso claro de cómo estará aprobada y supervisada una excepción.

Atributos de las políticas.

Las organizaciones deben crear políticas de seguridad antes de desarrollar una estrategia de seguridad.

- ☐ Las políticas de seguridad deben ser una articulación de una estrategia de seguridad de la información bien definida que capta la intención, las expectativas y la dirección de la gestión.
- ☐ Deben ser claras y de fácil comprensión por todas las partes afectadas.
- ☐ Deben ser cortas y concisas, escritas en un lenguaje sencillo.

DOCUMENTOS DE CUMPLIMIENTO

- 
- Políticas
 - Normas
 - Procedimientos

MARCOS DE POLÍTICA



Forma en que los documentos de cumplimiento se relacionan y se apoyan entre sí.

Tipos de Documentos de Cumplimiento.

Tipo	Descripción
Políticas	Comunica comportamientos y actividades requeridos y prohibidos
Normas	Interpreta políticas en situaciones específicas
Procedimientos	Proporciona detalles de cómo cumplir con normas y políticas
Directrices	Proporciona una guía general en asuntos tales como "qué hacer en situaciones específicas". Estos no son requerimientos que deban de cumplirse, pero son muy recomendados.

TIPOS DE POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN

El número y el tipo de políticas que la organización opte por aplicar varían en función del tamaño, la cultura, el riesgo, los requisitos regulatorios y la complejidad de las operaciones de dicha organización.



Política de Seguridad de Información General.



Políticas de seguridad.

Seguridad de la información:

- ☐ Definición de la empresa de seguridad de la información
- ☐ Responsabilidades asociadas con la seguridad de la información.
- ☐ La visión de seguridad de la información.
- ☐ Alineación de la política de seguridad con otras políticas de alto nivel.

Control de acceso:

- ☐ Permisos de acceso insuficientes.
- ☐ Número de incidentes de segregación de funciones.
- ☐ A partir de la política de control se debe garantizar que el acceso de emergencia sea permitido y revocado de manera oportuna.

Proteccion de datos personales:

- ❖ Verificación de antecedentes regulares.
- ❖ Verificar información sobre el personal.
- ❖ Desarrollo plan de sucesión para puestos clave.
- ❖ Implementar procedimientos adecuados para la terminación – revocar privilegios.

Política de Respuesta a Incidentes de Seguridad.

La política debe incluir:

- ❖ Definición de un incidente de seguridad de información
- ❖ Manejo de incidentes
- ❖ Requisitos para establecer el equipo de respuesta a incidentes (roles y responsabilidades).
- ❖ Requisitos para la creación de un plan de respuesta a incidentes, apoyado en procedimientos y directrices:
 - Criticidad de incidentes
 - Procesos de informes
 - Recuperación
 - Objetivos de tiempo de recuperación (RTO).
 - Investigación y conservación del proceso.
 - Pruebas y capacitación.
 - Reuniones posterior a los incidentes presentados para documentar causa raíz y mejoras de las prácticas de seguridad.
- ❖ Documentación de Incidentes y cierre.

GESTIÓN DE IDENTIDADES

OBJETIVO: Centralizar y estandarizar el proceso de gestión de identidades para que se convierta en un servicio consistente y común en toda la organización.

Establecimiento y mantenimiento de los perfiles de usuario.

- ☐ controles de autenticación, autorización y acceso para cada usuario.
- ☐ Racionalización de los diversos procesos de negocio para gestionar todas las formas de identidades. (inscripción – retiro).

COMPONENTES

- ◆ Servicios de directorios
- ◆ Servicios de autenticación
- ◆ Servicios de autorización
- ◆ Aprovisionamiento de usuarios y el desabastecimiento.

Autorización.

El proceso de autorización debe estar en capacidad de identificar y diferenciar entre los usuarios.

- ☐ Las reglas de acceso especifican quién puede acceder a qué. **Menor privilegio.**
- ☐ El acceso debe estar en una base documentada donde se especifique la “**necesidad de conocer**” y “**necesidad de hacer**”.

Niveles de acceso a un recurso:

- Archivos.
- Tablas.
- Elementos de datos.

Restricciones

- Sólo lectura, consulta o copia.
- Sólo escribir, creara, actualizar o eliminar.
- Sólo ejecutar.
- Combinación de privilegios.

Lista de Control de Acceso.

Conocidas como ACL, llevan un registro de usuarios donde se especifica que permisos tiene asignado un usuario para utilizar un recurso particular.

LISTAS DE ACCESO: Filtran el tráfico en las interfaces del router.

GESTIÓN DE USUARIOS PRIVILEGIADOS.

- ☐ Limitar el acceso privilegiado
- ☐ verificaciones de antecedentes
- ☐ registro adicional de actividad
- ☐ Rendición de cuentas mediante no compartir cuentas privilegiadas
- ☐ Contraseñas robustas
- ☐ Revisar periódicamente los privilegios de las cuentas y eliminar los que ya no se requieren

Asegurar que los cambios a procesos, sistemas, software, aplicaciones, plataformas y configuraciones se den de una manera ordenada y controlada.

GESTIÓN DE LA CONFIGURACIÓN.

El mantenimiento de las configuraciones de seguridad de los dispositivos de red, sistemas, aplicaciones y otros recursos de TI es de vital importancia para garantizar que los controles de seguridad estén correctamente instalados y mantenidos.

BENEFICIOS

- Verificación del impacto
- Evaluación del riesgo de una propuesta de cambio
- Inspección diferentes líneas de defensa para identificar posibles vulnerabilidades.
- Línea base de configuración de seguridad aprobada.
- Investigación después de una falla de seguridad.
- Control de versiones.

- ❖ Solucionan errores de programación ante vulnerabilidades de seguridad.
- ❖ Con la gestión de parches se busca actualizar los dispositivos tan pronto sea identificada la falla.
- ❖ Causa más común de las brechas.



TEMAS DEL CURSO

1. INTRODUCCIÓN Y VISIÓN GENERAL DE LA CIBERSEGURIDAD

2. CONCEPTOS DE LA CIBERSEGURIDAD

3. PRINCIPIOS DE ARQUITECTURA DE SEGURIDAD

4. SEGURIDAD DE REDES, SISTEMAS, APLICACIONES Y DATOS

5. RESPUESTA A INCIDENTES

6. IMPLICACIONES DE SEGURIDAD Y ADOPCIÓN DE LA TECNOLOGÍA

VISIÓN GENERAL DE LA ARQUITECTURA DE SEGURIDAD

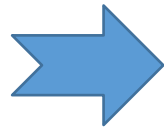
❖ Describe la estructura, componentes, conexiones y diseño de controles de seguridad dentro de la estructura de TI de una organización.

❖ Cada organización tiene diferentes tipos arquitecturas que están determinadas por:

☐ Subsistemas

☐ Productos

☐ Aplicaciones



Influyen en el enfoque para la **defensa en profundidad** o la practica de múltiples capas de defensa

LA ORGANIZACIÓN VIRTUAL

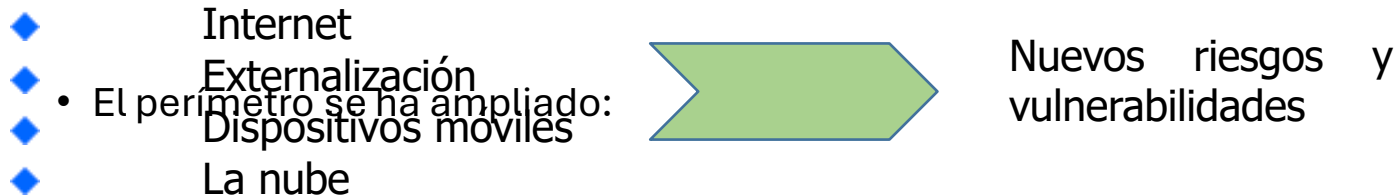
La externalización (**outsourcing**), es cada vez más común a medida que las empresas se centran en las competencias básicas y en formas de reducir costos.

- No están exentos de riesgos y deben afrontar varios desafíos:
 - ❖ Difíciles de cuantificar y potencialmente difíciles de mitigar.
 - ❖ Manejo de recursos y funciones externalizadas.
 - ❖ Los proveedores pueden operar en diferentes estándares y pueden ser difíciles de controlar.
 - ❖ Los riesgos también pueden materializarse como resultado de Fusiones y adquisiciones

Dentro de la estrategia de seguridad se debe tener en cuenta los servicios de seguridad externalizados con el fin de asegurar que no se convertirán en un único punto de falla crítica y que se cuenta con un plan de respaldo en caso de falla por parte del proveedor de servicios.

PERIMETRO DE SEGURIDAD

- En los modelos de ciberseguridad, el foco está centrado en la **datos** o **sistemas**.
- **Sistema:** Énfasis en la colocación de los controles a nivel de red y del sistema para proteger la información almacenada en el interior.
- **Centrado de datos:** Hace referencia a la protección de los datos independientemente de su ubicación.



En conclusión

El perímetro es una **importante línea de defensa** que protege la empresa contra amenazas externas y su diseño debe reflejar una actitud proactiva hacia la prevención de riesgos.

ARQUITECTURAS Y MARCOS DE SEGURIDAD

Los modelos de arquitectura de seguridad se dividen en dos categorías:

Modelos de proceso: Más directivo en su enfoque de los procesos utilizados para los distintos elementos.

Modelos de marcos: Permiten una gran flexibilidad en cómo se desarrolla cada elemento de la arquitectura.

Describen los elementos de la arquitectura y cómo éstos se relacionan entre sí.

MARCO SABSA Y EL ZACHMAN

MARCO ZACHMAN: desarrolla la matriz de quién, qué, por qué, dónde, cuándo y cómo.

MARCO SABSA (Arquitectura de Seguridad Aplicadas a los Negocios de Sherwood): proporciona una estructura lógica para la clasificación y organización de elementos de diseño, lo que mejora la integridad de la arquitectura de seguridad.

	Activos (Qué)	Motivación (Por qué)	Proceso (Como)	Personas (Quién)	Localización (Dónde)	Tiempo (Cuando)
Contextual	El negocio	Modelo de riesgo del negocio	Modelo de procesos del negocio	Organización y relaciones empresariales	Geografía del negocio	Dependencias de tiempo del negocio
Conceptual	Perfil de atributos del negocio	Objetivos de control	Estrategias de seguridad y arquitectura por capas	Modelos de entidad de seguridad y marco de confianza	Modelo de dominio de seguridad	Tiempos de vida y plazos relacionados con la seguridad
Lógico	Modelo de información del negocio	Políticas de seguridad	Servicios de seguridad	Esquemas de entidad y perfiles de privilegios	Definiciones y asociaciones del dominio de seguridad	Ciclo de procesamiento de seguridad
Físico	Modelo de datos del negocio	Reglas, prácticas y procedimientos de seguridad	Mecanismos de seguridad	Usuarios, Aplicaciones e interfaz de usuarios	Infraestructura de la plataforma y la red	Ejecución de la estructura de control
Componente	Estructuras de datos detallada	Estándares de Seguridad	Productos y herramientas de seguridad	Identidades, funciones, acciones y ACLs	Procesos, nodos, direcciones y protocolos	Calendario y secuencia de los pasos de seguridad
Operacional	Aseguramiento de la continuidad operativa	Gestión del riesgo operacional	Gestión y soporte de servicios de seguridad	Aplicación y gestión de usuarios y soporte	Seguridad de los sitios, redes y plataformas	Horario de las operaciones de seguridad

Esquema de Arquitectura del Open Group (The Open Group Architecture Framework, TOGAF).

- ❑ Aborda la seguridad como un componente esencial de la concepción global de la empresa.
- ❑ **Objetivo:** asegurar que los proyectos de desarrollo de arquitectura cumplan los objetivos del negocio, que sean sistemáticos y que sus resultados sean repetibles.



MODELO OSI

Capa física => Gestiona señales entre los sistemas de red.

Capa de enlace de datos => Divide los datos en tramas.

Capa de red => Traduce direcciones de red y dirige los datos del emisor al receptor.

Capa de transporte => Asegura que los datos se transfieran de forma fiable.

Capa de sesión => Coordina y gestiona las conexiones de usuario.

Capa de presentación => Da formato, cifra y comprime los datos.

Capa de aplicación => Media entre aplicaciones de software y otras capas de servicios de red.



Incluye protocolos orientados a redes como protocolos de soporte de aplicaciones. Pg. 48.

				TCP / IP			
	Modelo OSI	Capas Conceptual TCP/IP	Unidad de datos de protocolo (POU)	Protocolo TCP/IP	Equipo	Funciones de capa	Funciones de capa
7	Aplicación	Aplicación	Datos	HTTP Protocolo de Transporte de Archivos (FTP) Protocolo de Transporte de Correo Simple (SMTP) TFTP NFS Protocolo Servidor de Nombres(NSP) Protocolo de Gestión de Red Simple (SNMP) Protocolo de Control de Terminal Remoto (Telnet) LPD XWindows DNS DHCP/BootP	Portal	Aporta el interfaz de usuario	Servicios de archivos, impresión, mensajes, base de datos y aplicación
6	Presentación					Presenta los datos Maneja procesos como el cifrado	servicios de cifrado, compresión y traducción de datos
5	Sesión					Mantiene separados los datos de diferentes aplicaciones	Control de diálogo
4	Transporte	Transporte	Segmento	Protocolo de control de Transmisión (TCP) Protocolo de Datagramas de Usuarios (UDP)	switch Capa 4	Proporciona entrega confiable o no confiable	Conexión de extremo a extremo
3	Red	Interfaz de red	Paquete	ICMP ARP RARP Protocolo de Internet (IP)	Router switch Capa3	Proporciona dirección lógico el cual usan los router para determinar la ruta	Enrutamiento
2	Enlace de datos	Interfaz LAN o WAN	Marco	Ethernet Fast Ethernet FDDI Token Ring Protocolo punto a punto (PPP)	switch Capa 2 Bridge AP Inalámbrica NIC	Combina paquetes en bytes y los bytes en marcos Proporciona acceso a medios usando dirección MAC Realiza detección de error, no corrección de error	Enmarcado
1	Físico		Bits		Hub Repetidor	Mueve los bits entre los dispositivos	Topología física

ENCAPSULACIÓN

Añadir información de direccionamiento de datos a medida que se transmite por la pila del modelo OSI.

Utiliza **datagramas o unidades de datos de protocolo (PDU)**.

Los datos de la capa superior se transmiten a la **capa de transporte** como **segmentos** y son “envueltos” con una cabecera para su identificación.

Estos segmentos se transmiten a la **capa de red** en forma de **paquetes** con una cabecera. Los datos se desglosan en **marcos (tramas)** en la **capa de enlace de datos**. En la **capa física**, los datos son transmitidos en **bits**.

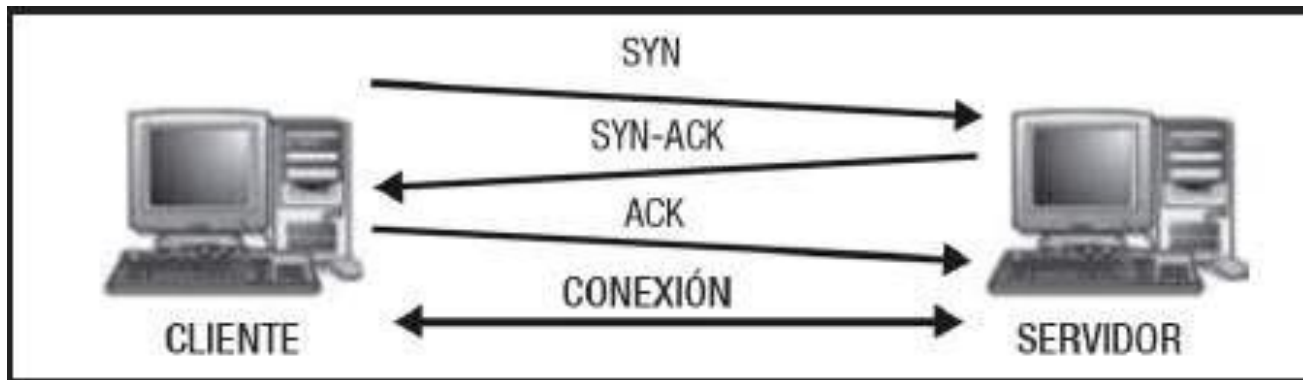
TCP:

- Proporciona una confiable, entrega secuenciada con comprobación de errores.
- 3-Way Handshake

UDP:

- Protocolo sin conexión donde la velocidad es más importante que la comprobación de errores y la entrega de datos.
- (checksums) – para validar la integridad de los datos.

3-Way Handshake



DEFENSA EN PROFUNDIDAD

Ningún control o contramedida pueden eliminar el riesgo.

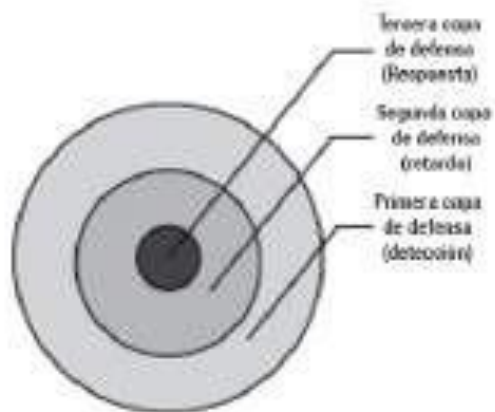
Es importante usar varios controles para proteger un activo.

VENTAJAS:

Aumento del esfuerzo que se requiere para un ataque con éxito.

Creación de oportunidades adicionales para detectar o retrasar un atacante.

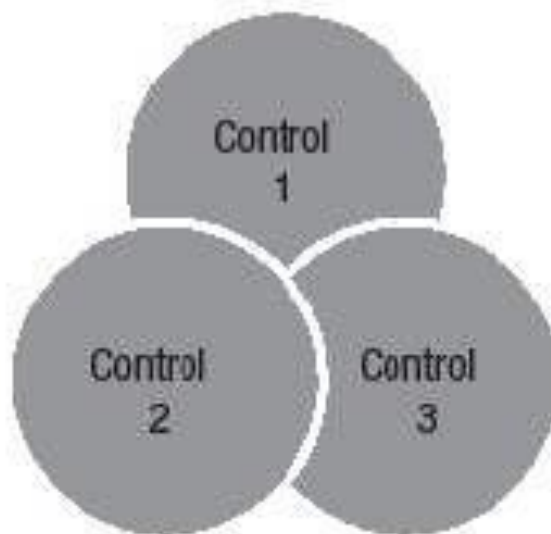
Anillos concéntricos
(o capas anidadas)



Crea una serie de capas anidadas que deben ser anuladas para completar un ataque.

Cada capa retarda al atacante y da oportunidad de detectar el ataque.

Redundancia
superpuesta



Dos o más controles que trabajan en paralelo para
proteger un activo

Proporciona puntos de detección múltiples y
superpuestos.

Esta es más efectiva cuando cada control es
diferente.

Segregación o
compartimentación



Compartimenta el acceso a un activo, requiriendo dos o más procesos, controles o individuos para acceder o usar el activo.

Ésta es efectiva al proteger activos de muy alto valor o en ambientes donde la confianza es un problema.

DEFENSA EN PROFUNDIDAD

Perspectiva de arquitectura:

- **Defensa en profundidad horizontal:** Los controles se colocan en **varios lugares**. Es equivalente al modelo de anillos concéntricos anterior.
- **Defensa en profundidad vertical:** Los controles se colocan en **diferentes capas del sistema** (hardware, sistema operativo, aplicaciones, bases de datos o niveles de usuario).

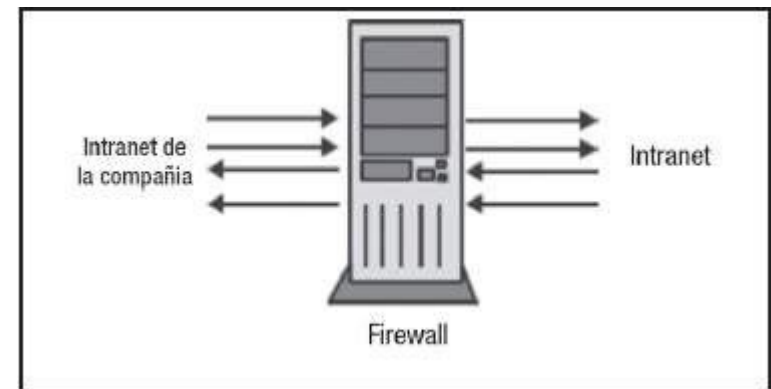
Consideraciones:

- ☐ ¿A qué vulnerabilidades se dirige cada capa o control?
- ☐ ¿Cómo afecta la capa a mitigar la vulnerabilidad?
- ☐ ¿De qué manera cada control interactúa con o depende de los otros controles?

- ☐ Sistema o combinación de sistemas que impone un límite entre dos o más redes.
- ☐ Controlar el tipo de tráfico que entra y sale de una red.
- ☐ Filosofía de negar todo.

CARACTERISTICAS

- ☐ Bloquear el acceso.
- ☐ Limitar el tráfico.
- ☐ Prevenir que los usuarios accedan a determinados servidores o servicios.
- ☐ Supervisar y registrar la comunicación (red interna, red externa y mundo exterior).
- ☐ Cifrar los paquetes que se envían entre diferentes ubicaciones físicas(VPN, IPSec)



PLATAFORMAS DE FIREWALL

FIREWALLS BASADO EN HARDWARE:

Ventajas: Son más rápidos.

Limitaciones: No son tan flexibles o escalables.

FIREWALL BASADO EN SOFTWARE:

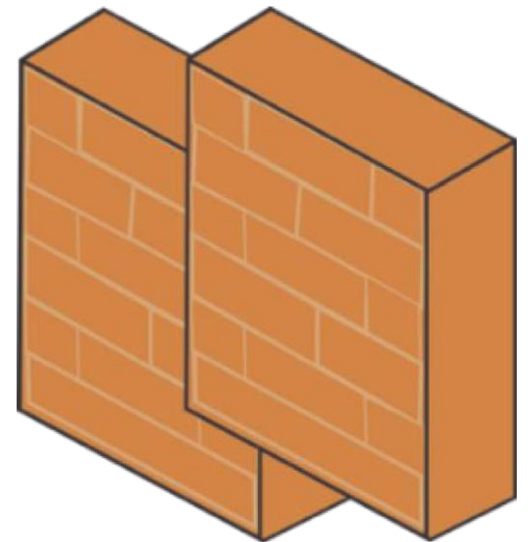
- ❖ Son generalmente más lentos con una significativa sobrecarga de los sistemas.
- ❖ Son flexibles con servicios adicionales

Es mejor utilizar appliances (dispositivos de propósito específico), en lugar de los servidores normales, son más rápidos de instalar y recuperarse.

Cuando se utilizan firewalls basados en servidores, los sistemas operativos en los servidores suelen ser vulnerables a los ataques.

TIPOS DE FIREWALL DE RED

- ✓ Filtrado de paquetes
- ✓ Sistemas de firewall de aplicación
- ✓ Inspección de estado (stateful Inspection)
- ✓ Firewall de próxima generación (NGFW)



ARQUITECTURA DE FIREWALLS

Firewall de host proyectado (screened-host firewall)— implementa la seguridad básica de capa de red (**filtrado de paquetes**) y la seguridad del servidor de aplicaciones (**servicios de proxy**).

Firewall de base dual (dual-homed firewall) — firewall con **dos o más interfaces de red**. Actúa para bloquear o filtrar algunos o todo el tráfico que trata de pasar entre las redes.

Firewall de zona desmilitarizada (DMZ) o firewall de subred proyectada — La DMZ conecta la red no fiable a la red de confianza. Como resultado, los sistemas externos pueden acceder solo a la DMZ.

Un intruso debe penetrar tres dispositivos separados, las direcciones de red privadas no se dan a conocer a la Internet y los sistemas internos no tienen acceso directo a Internet.

PROBLEMAS DE FIREWALL

- ✓ **Errores de configuración**— pueden permitir que servicios desconocidos y peligrosos pasen libremente.
- ✓ **Demandas de monitoreo**— Es necesario aplicar y revisar la configuración de la bitácora (log) adecuadamente.
- ✓ **Las políticas de mantenimiento** — Las políticas de firewall podrían no mantenerse con regularidad.
- ✓ **La vulnerabilidad a los ataques basado en aplicaciones e ingreso de datos (input)** — La mayoría de los firewalls operan en la capa de red; por lo tanto, no detienen ningún ataque basado en aplicaciones.
- ✓ Los **firewalls de nueva generación** son capaces de inspeccionar el tráfico en la capa de aplicación y detener algunos de estos ataques. .

AISLAMIENTO Y SEGMENTACIÓN

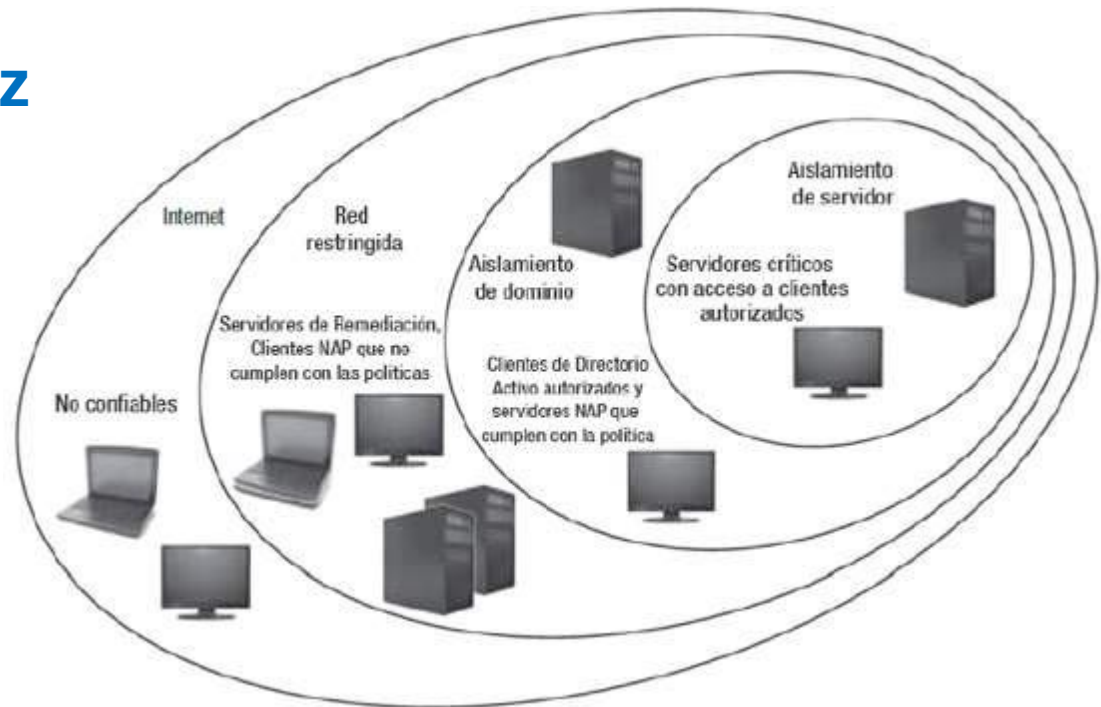
VLANs: Segmentar la red de una organización.

Son grupos de dispositivos en una o más LAN segmentadas lógicamente.

En la capa 4 de conmutación, parte de la información de aplicaciones se toma en cuenta junto con la capa 3 direcciones.

ZONAS DE SEGURIDAD Y DMZ

Utilizando dos routers de filtrado de paquetes y un Servidor bastión, este enfoque crea el sistema de firewall más seguro porque implementa la seguridad a nivel de la red y de aplicación, esto con definir una red DMZ separada.



- ☐ Un intruso debe penetrar tres dispositivos separados
- ☐ Las direcciones de red privadas no se dan a conocer en Internet
- ☐ Los sistemas internos no tienen acceso directo a Internet

Son partes integrales de la ciberseguridad

Es necesario monitorear los datos e información que fluye hacia dentro y fuera de la organización.

INGRESO, SALIDA, Y PREVENCIÓN DE PERDIDA DE DATOS (DLP)

Vectores de ataque: Ingreso y Salida.

Ingreso: Hace referencia a las comunicaciones de la red que entran.

Salida: Hace referencia a las comunicaciones de la red que salen.

Las **Soluciones DLP** cubre tres estado primarios

- **Datos en reposo:** Datos almacenados. Las aplicaciones gusano exploran la información en esta búsqueda de archivos para datos vulnerables como la seguridad social o información de la tarjeta de crédito.
- **Datos en movimiento:** Hace referencia a los datos que viajan a través de la red
- **Datos en Uso:**
 - Datos en movimiento a nivel de la estación de trabajo del usuario.
 - Envían información a las impresoras, mover drivers o incluso copiar y pegar en el portapapeles.

Un **IDS** opera continuamente en el sistema, ejecutándose en un segundo plano y notificando a los administradores cuando detecta una amenaza.

Categorías de IDS

IDS basados en la red —> Identifican ataques dentro de la red monitoreada y envían una advertencia al operador.

- ☐ **IDS entre internet y el firewall:** Detectará los intentos de ataques, sin importar si entran al firewall.
- ☐ **IDS entre el firewall y la red corporativa:** Detectará los ataques que entren al firewall.

El IDS no es un sustituto de un firewall, sino que complementa su función.

IDS basados en el Servidor —> Monitorean varios recursos internos del sistema operativo para prevenir posibles ataques.

Pueden detectar la modificación de programas ejecutables, detectar la eliminación de archivos y emitir una advertencia cuando se intenta la ejecución de un comando privilegiado.

COMPONENTES DE UN IDS

- ☐ Sensores para la recolección de datos.
- ☐ Analizadores que reciben el input de sensores e identifican la actividad intrusiva.
- ☐ Consola de administración.
- ☐ Interface de usuario.

TIPOS DE IDS

Basado en firma — Protegen en contra de patrones de intrusión detectados. Los patrones de intrusión que son identificados son almacenados en forma de firmas.

Basado en estadística — Necesita una definición comprehensiva de los patrones de comportamiento conocidos y esperados de los SI.

Redes neuronales —Monitorea los patrones generales de la actividad y el tráfico de la red, creando una base de datos.

FUNDAMENTOS DE CIFRADO

Proceso de convertir un mensaje en texto plano a una forma codificada segura de texto.

El cifrado está **sujeto a leyes gubernamentales y regulaciones** que limitan el tamaño de la clave o definen lo que no puede ser encriptado.

El cifrado es parte de la criptografía la cual es usada para:

- ❖ Proteger información almacenada de manipulación e inspecciones no autorizadas.
- ❖ Proteger datos en tránsito.
- ❖ Impedir y detectar alteraciones accidentales o intencionales.
- ❖ Verificar la autenticidad de una transacción.

Limitaciones: El cifrado no puede prevenir la pérdida de datos.

El cifrado debe ser visto como esencial pero incompleta.



ELEMENTOS CLAVE DE SISTEMAS CRIPTOGRÁFICOS

- **Algoritmo de cifrado** => Función matemática que cifra o descifra los datos.
- **Clave de cifrado** => Información similar a una contraseña que hace que el proceso de cifrado y descifrado sean únicos.
- **Longitud de la Clave** => Cuanto más larga sea la clave, es más difícil comprometer en un ataque de fuerza bruta.

FACTORES

- ☐ Fuerza de algoritmo.
- ☐ Discreción y dificultad de comprometer una clave
- ☐ No existencia de puertas traseras
- ☐ Inhabilidad de descifrar partes de un mensaje de texto codificado con el fin de prevenir ataques de texto plano conocidos.
- ☐ Propiedades de un texto plano conocido por un perpetrador

SISTEMAS CLAVE

Tipos de sistemas criptográficos

- ❖ **Sistemas de clave simétrica:** Usa una clave única, secreta y bidireccional que cifra y descifra.
- ❖ **Sistemas de clave asimétrica:** Utiliza una clave para cifra y la otra para descifrar.
- ❑ La mayoría de las transacciones cifradas en internet usan una **combinación de claves privadas y públicas, claves secretas, funciones hash y certificados digitales** (que prueban la posesión de una clave pública de cifrado). Todo esto para alcanzar **confidencialidad, integridad del mensaje, autenticación y no repudio (rechazo)**.
- ❑ Infraestructura de clave pública PKI.

TÉCNICAS DE CIFRADO

CLAVE DE CIFRADO SIMETRICA (PRIVADA)

Basados en un algoritmo de cifrado simétrico. - La clave de cifrado es la misma que la clave de descifrado.

DES => Utiliza bloques de 64 bits. - Sistema criptográfico de clave simétrico más común.
Algoritmo avanzado de cifrado => 3 DES.

DES fue reemplazado por **AES**: Algoritmo público soporta claves de 128, 256 o 512 bits.

VENTAJAS

- ☐ Solo se debe recordar una clave tanto para el cifrado como descifrado.
- ☐ Son menos complicados. por usan menos procesamiento que las técnicas asimétricas.
- ☐ Idealmente adaptados para el cifrado de datos masivo.

DESVENTAJAS

- Dificultad de distribución de las claves - ambientes de comercio electrónico donde los clientes son entidades desconocidas y sin una relación de confianza.
- Limitaciones de secreto compartido - Una clave simétrica no puede ser usada para firmar documentos electrónicos o mensajes.

CLAVE DE CIFRADO ASIMÉTRICA (PRIVADA)

- Desarrollado para distribución de claves.

Situación: 2 personas que no se conocen entre si pero quieren intercambiar información de forma segura.

- Una vez que la clave ha sido usada para codificar los datos, solo su compañera puede ser usada para descifrar los datos.
- La clave usada para cifrar los datos no puede ser usada para descifrar.
- Las claves asimétricas están inversamente relacionadas.
- Con base a la factorización, las claves asimétricas generan un producto único de dos números, haciendo impráctico factorizar este numero y recuperar los dos factores.
- El sistema requiere aritmética modular, exponenciación y números primarios grandes, de miles de bits de largo.
- Usadas para mensajes cortos, como cifrar las claves simétricas o crear firmas digitales.
- **Clave privada** -> Conocida solo por una persona.
- **Clave pública** -> Conocida por muchos.
- Un mensaje cifrado con una clave pública puede ser generado por cualquier persona pero solo puede ser leído por el destinatario

CRIPTOGRAFIA DE CURVA ELÍPTICA

- ❑ Forma alternativa y más eficiente de criptografía de clave pública es la criptografía de curva elíptica (ECC).
- ❑ Incrementa la seguridad usando recursos mínimos.
- ❑ **Limitaciones:** Acho de banda y poder de procesamiento.

CRIPTOGRAFÍA CUÁNTICA

- ❖ Siguierte generación de criptografía.
- ❖ Resuelve algunos problemas asociados con la generación aleatoria y asegura la distribución de claves criptográficas simétricas.
- ❖ Leyes físicas (fotones).

ESTÁNDAR DE ENCRIPCIÓN AVANZADA

AES => Utiliza el algoritmo Rijndael => Código de bloque simétrico de tamaño (128, 192, y 256).

- ❖ Código está basado en una substitución.
- ❖ de bytes, cambiando filas, mezclando columnas y agregando claves circulares que son repetidas cada 10 rondas.
- ❖ Puede ser implementada eficientemente en hardware.
- ❖ El descifrado es calculado aplicando funciones inversas la cual es resultado de circuitos separados de cifrado y descifrado.
- ❖ Las operaciones de la función en serie inversa son más complejas que la operación respectiva de cifrado.

FIRMA DIGITAL

- ☐ Identificación electrónica mediante un algoritmo de clave pública.
- ☐ Usada como mecanismo para verificar la integridad de los datos y la identidad del remitente.
- ☐ **Verificación de integridad** -> Función de hashing «**Checksum**». Genera una pequeña cadena de valores de largo definido, **usualmente de 128 bits**

Crea un resumen de validación de bits (digest):

- ☐ **SHA 1**
- ☐ **SHA 2**
- ☐ **MD2**
- ☐ **MD4**
- ☐ **MD5**

FUNCIONES DE SENTIDO UNICO

MD2 fue optimizado para máquinas de 8 bits. **MD4 y el MD5 creados para máquinas de 32 bits.**

Para cifrar un mensaje, el remitente usa una clave privada, para descifrarlo, el destinatario utilizara la llave publica del remitente.

Una vez descifrado, el destinatario recalculará el hash usando el mismo algoritmo de función de hashing que se encuentra en el documento electrónico y se compararán los resultados con lo que fue enviado, para **asegurar la integridad del mensaje.**

FIRMA DIGITAL

- Una firma digital asegura:
 - **Integridad de los datos** — Cualquier cambio en el texto del mensaje repercute con la imposibilidad del destinatario del mensaje de calcular el mismo hash del mensaje.
 - **Autenticación** — Asegurar que el mensaje ha sido enviado por el remitente declarado.
 - **No repudio** — El remitente no puede negar la generación y envío del mensaje.
- ❑ Las firmas digitales y el cifrado de clave pública son vulnerables a ataques **MiTM**
- ❑ Para protegerse de tales ataques, se ha diseñado una autoridad de autenticación de remitente independiente.
- ❑ PKI desempeña la función de autenticar de forma independiente la validez de la firma digital del remitente y las claves públicas.

- Intercambia datos seguros a través de Internet.
- IPSec utiliza algoritmos de cifrado:
- DES (Claves de 56 bits) Boques de 64 bits
- 3DES (Claves de 168 bits)
- AES (Claves de 128, 192 o 256 bits) Bloques de 128.

RED VIRTUAL PRIVADA

PROTECCIONES DE REDES INALÁMBRICAS.

- ☐ Un email puede ser interceptado y leído o modificado.
- ☐ Los hackers pueden reemplazar las credenciales de un usuario con información falsa que lleva al servidor de destino a rechazar los intentos de acceso del usuario, causando así denegación del servicio (DoS).
- ☐ Una persona no autorizada puede acceder a una red inalámbrica no segura y usar sus recursos, incluyendo conectividad a internet gratis.
 - ❖ WEP
 - ❖ WPA: Limitaciones => La clave esta protegida por una clave de acceso que no tiene una longitus robusta.
 - ❖ WPA2 – **802.11i**
- **WEP y WPA** son aplicables a la mayoría de las redes inalámbricas
- **ECC** usado en tarjetas inteligentes

El destinatario puede vincular el mensaje a una persona.

El estado y valores del certificado debe incluir:

- Un nombre de usuario distintivo
- Una clave pública real
- El algoritmo usado para incorporar la firma digital dentro del certificado
- Un periodo de validez del certificado

Autoridad de certificación (CA): Emite y maneja credenciales de seguridad y claves públicas para la verificación de mensajes de firmas o cifrado.

- ☐ CA consulta a una **Autoridad de Registro (RA)** para verificar la información proveniente del solicitante del certificado digital. Si la RA verifica la información del solicitante, entonces la CA puede entonces emitir el certificado.
- ☐ La CA firma el certificado con su clave privada para distribuirlo al usuario.

Tipos de CA pueden incluir:

- **Organizacionalmente fortalecidas** => Tienen control coercitivo sobre aquellos individuos dentro de su alcance.
- **Responsabilidad fortalecida** => Opciones comerciales disponibles (VeriSign) para obtener un certificado digital.

APLICACIONES DE CIFRADO.

APLICACIONES DE SISTEMA DE CIFRADO.

Requieren una combinación de parejas de claves públicas y privadas, claves secretas, funciones hash y certificados digitales.

Propósito: Confidencialidad, integridad del mensaje o no repudio por parte del remitente o del destinatario.

Proceso:

1. Se requiere que el remitente realice un **hashing** del mensaje dentro de un mensaje cifrado o codifique un pre-hash para mantener la integridad del mensaje, este se encripta usando la clave secreta del remitente para preservar la autenticidad, integridad y no repudio (firma digital).
2. el remitente **firmará** el mensaje con su clave secreta.
3. la clave secreta se **cifrá** con la clave pública del receptor.
4. A través de la validación del certificado digital se otorga la confidencialidad del mensaje.

En la validación, el contenido calcula un código post-hash, el cual debe ser igual al código pre-hash.

Capa de Conector Seguro (SSL) y Seguridad de la Capa de Transporte (TLS)

Protocolos criptográficos que proveen de una comunicación segura en Internet.

SSL: Protocolo de sesión - o conexión usado para comunicación entre navegadores y servidores de red.

- ❖ Provee autenticación al final del extremo y privacidad de comunicaciones en Internet.
- ❖ Solo el servidor está autenticado mientras el cliente permanece sin autenticarse.
- ❖ La autenticación mutua requiere de infraestructura PKI

FASES:

- ☐ Negociación entre los pares para soporte del algoritmo.
- ☐ Clave pública, intercambio de claves basada en cifrado y autenticación basada en el certificado.
- ☐ Cifrado de tráfico basado en cifrado simétrico.

HTTPS usa certificados de claves públicas para verificar la identidad del otro extremo. SSL usa un proceso criptográfico híbrido de hash, clave pública y privada para asegurar transacciones en internet a través de PKI.

Protocolo de Transferencia de Hipertexto Seguro (S/HTTP)— Transmite mensajes individuales o páginas de forma segura entre un cliente web y un servidor estableciendo una conexión de tipo SSL. Dirige el mensaje hacia un número de puerto seguro en lugar de la dirección de puerto web por defecto. Utiliza las características de seguridad de SSL pero lo hace más bien como mensaje en lugar de un protocolo orientado a sesión.

IPSec:

Establece VPNs a través de métodos de cifrado en modo transporte y túnel.

Método de transporte: Las **porciones de datos de cada paquete (ESP) – son cifradas** para alcanzar la confidencialidad.

Modo túnel: el **encapsulado ESP y su encabezado son cifrados**. Para alcanzar el no repudio, aplica un encabezado de autenticación (**AH**).

En cualquier modo, se realizan **Asociaciones de Seguridad (SAs)**. Las SAs definen cuales son los **parámetros** de seguridad que deben aplicarse entre las partes de la comunicación como **algoritmos de cifrado, claves, vectores de inicialización, rango de vida de claves**, etc.

Para incrementar la seguridad de IPSec, **usa cifrado asimétrico (ISAKMP/Oakley)**, el cual permite la administración de claves, uso de claves públicas, negociación, establecimiento, modificación y **supresión de SAs y sus atributos**.

APLICACIONES DE CIFRADO.

Secure Shell (SSH): Programa cliente-servidor por línea de comandos segura, cifrada para un acceso seguro.

- ☐ SSH valida las credenciales de ambas partes vía certificados digitales. SSH es útil en asegurar los servicios Telnet y FTP.
- ☐ Utilizado en la capa de aplicación,
- ☐ IPSec: Capa de red.

Extensiones Multipropósito Seguras de Correo de Internet (S/MIME): Protocolo de seguridad estándar de email que valida la identidad del remitente y del destinatario, verifica la integridad del mensaje y asegura la privacidad del contenido.

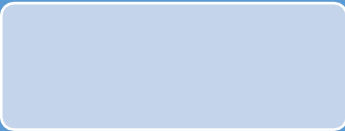
Transacciones Electrónicas Seguras (SET): Protocolo desarrollado conjuntamente por VISA y MasterCard para asegurar transacciones de pago.

- Utiliza procesos de **cifrado** de terceros de confianza y **firma digital**.
- **PKI:** Confidencialidad de la información, integridad de los datos, autenticidad del titular de la tarjeta, autenticidad del comercio e interoperabilidad.

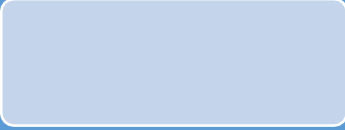
RIESGO DEL CIFRADO Y PROTECCIÓN DE LA CLAVE.

La seguridad de los métodos de cifrado descansa principalmente en el secreto de las claves. cuanto más se usa una clave, más vulnerable se vuelve ante una amenaza.

- ❑ La aleatoriedad en la generación de claves también es un factor significativo a la hora de comprometer una clave.
- ❑ Cuando las contraseñas se encuentran ligadas a una generación de claves, la fuerza de cifrado del algoritmo se ve disminuida, en particular cuando se usan palabras comunes.
- ❑ Una contraseña de **8 caracteres** es comparable a una clave de **32 bits**.
- ❑ Una contraseña que carece de aleatoriedad **disminuirá** las capacidades de cifrado de un algoritmo de **128 bits**.
- ❑ Es esencial establecer reglas de sintaxis de contraseñas efectivas y que las contraseñas fácilmente adivinables sean prohibidas.



1. INTRODUCCIÓN Y VISIÓN GENERAL DE LA CIBERSEGURIDAD



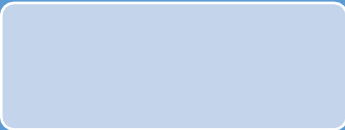
2. CONCEPTOS DE LA CIBERSEGURIDAD



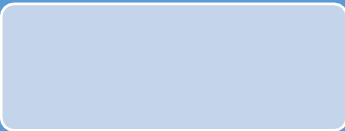
3. PRINCIPIOS DE ARQUITECTURA DE SEGURIDAD



4. SEGURIDAD DE REDES, SISTEMAS, APLICACIONES Y DATOS



5. RESPUESTA A INCIDENTES



6. IMPLICACIONES DE SEGURIDAD Y ADOPCIÓN DE LA TECNOLOGÍA

Riesgo: Posibilidad de pérdida de un activo digital resultado de una amenaza explotando una vulnerabilidad.

Evaluación de ciber riesgo: Determina el riesgo particular de una organización.



EVALUACIÓN DE RIESGOS

El análisis de riesgo se pueden orientar hacia una de las entradas, haciendo la evaluación del riesgo orientada al activo, orientada a la amenaza u orientada a la vulnerabilidad.

Orientación	Descripción
Activo	Se definen primero los activos importantes, y después son analizadas las amenazas potenciales a esos activos. Se identifican las vulnerabilidades que podrían ser aprovechadas para acceder al activo.
Amenaza	Se determinan primero las amenazas potenciales, y después se desarrollan los escenarios de amenazas. Basados en los escenarios, se determinan las vulnerabilidades y los activos de interés para el adversario en relación a la amenaza.
Vulnerabilidad	Se identifican primero las vulnerabilidades y deficiencias, después los activos expuestos, y luego son determinados los eventos de amenaza que podrían ser utilizados como ventaja.

EVALUACIÓN DE LOS CONTROLES DE SEGURIDAD

Una vez que el riesgo es identificado y priorizado, los controles existentes deben ser analizados para determinar su efectividad para mitigar el riesgo.

Clasificación del riesgo basado en:

- ☐ Controles Adecuados
- ☐ Controles inadecuados
- ☐ Sin controles.

CONTROLES DE PROCESO – GESTIÓN DE LA VULNERABILIDAD

Las organizaciones deben identificar y evaluar las vulnerabilidades para determinar la amenaza y el impacto potencial para determinar un plan de acción adecuado para hacer frente a cada vulnerabilidad.

Identificación de Vulnerabilidades:

- ☐ Información proporcionada por los distribuidores.
- ☐ Uso de procesos y herramientas que identifican vulnerabilidades conocidas.

Técnicas:

- ☐ Análisis de vulnerabilidades
- ☐ Pruebas de penetración.

GESTIÓN DE VULNERABILIDADES

- Comprensión de los activos de ciberseguridad (físicos o lógicos).
- Inventario de activos que detalla información importante acerca de cada activo cibernético tal como la ubicación, criticidad del activo, el dueño organizacional del activo y el tipo de información.

ESCANEO DE VULNERABILIDADES

Las herramientas de evaluación de la vulnerabilidad se dividen en dos categorías: basadas en host y basadas en red.

Se debe investigar y seleccionar las herramientas con base a las necesidades de las empresas y en el retorno de la inversión.

EVALUACIÓN DE VULNERABILIDADES

- ☐ Vulnerabilidad: Debilidad explotable que se traduce en una pérdida.
- ☐ Exploit: Método para explotar una vulnerabilidad
- ☐ Herramientas de análisis: SANS, MITRE, OWASP.

Tipo de Vulnerabilidad	Causa	Ejemplo de Ciberseguridad
Técnica	Errores de diseño, implementación ubicación o configuración	Errores de cifrado, contraseñas inadecuadas, puertos de red abiertos, falta de monitoreo
De proceso	Errores en la operación	Falta de monitoreo de los registros (logs). Falta de parcheo del software
Organizacional	Errores en la gestión, las decisiones, la planificación o debidos a la ignorancia	Falta de políticas, falta de concienciación, fallos al implementar controles
Emergente	Interactions between, or changes in, environments	Fallos entre organizaciones, errores de interoperabilidad al implementar nuevas tecnologías

CONTROLES DE PROCESO – PRUEBA DE PENETRACIÓN

Identificación de las vulnerabilidades existentes con el fin de utilizar exploits para:

- Comprometer el activo.
- Evaluar el nivel de eficacia y la calidad de los controles de seguridad existentes.
- Identificar cómo las vulnerabilidades específicas exponen los recursos de TI y los activos.
- Asegurar el cumplimiento.

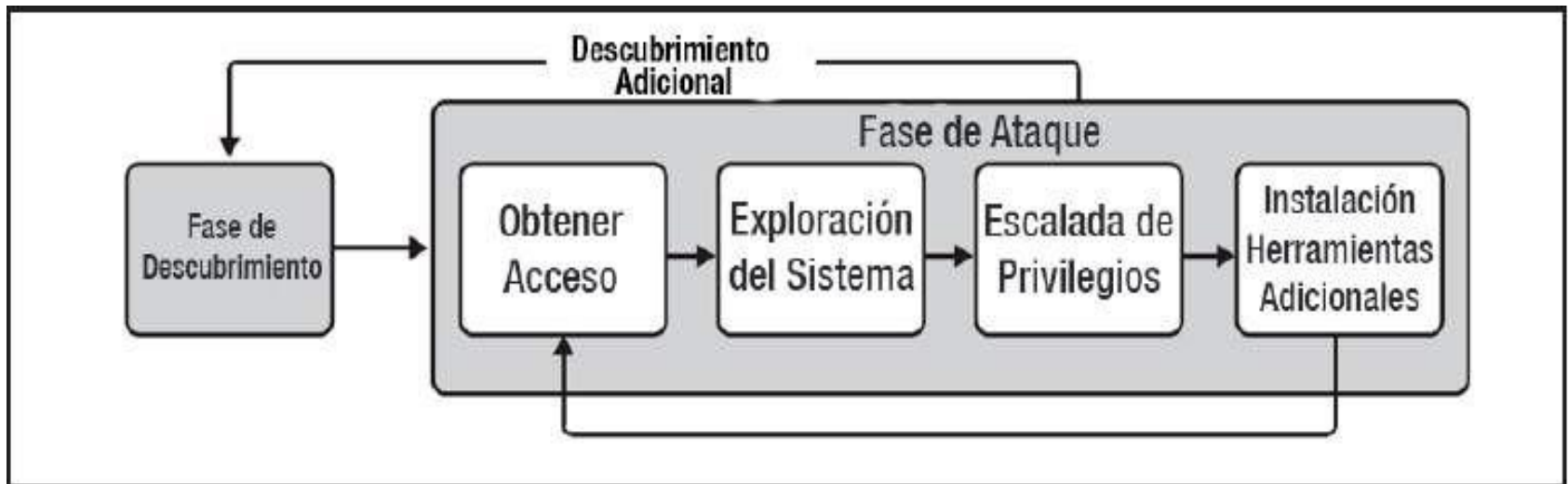
Es importante planificar cuidadosamente estas pruebas.

CONSIDERACIONES

- ❖ Definir claramente el alcance
- ❖ Recabar permiso escrito explícito de la organización (autorización de la prueba). Distinguir el servicio como autorizado y legal.
- ❖ Asegurar procedimientos “Do no harm” (“**no hacer daño**”) para garantizar que los activos no se vean perjudicados.
- ❖ Establecer planes de comunicación.

FASES PRUEBAS DE PENETRACIÓN

Las pruebas de penetración pueden ser encubiertas de tipo internas o externas.



SEGURIDAD DE LA RED

GESTIÓN DE REDES

Proceso de evaluación, monitoreo y mantenimiento de los dispositivos de red y las conexiones.

ÁREAS FUNCIONALES (FCAPS)

Gestión de Errores — Detectar, aislar, notificar y corregir errores encontrados en la red. Análisis de tráfico, tendencias, consultas SNMP y alarmas para la detección automática de errores.

Gestión de la Configuración — Aspectos de la configuración de dispositivos de red (gestión de archivos de configuración, gestión de inventario y gestión de software).

Gestión de las Cuentas — Uso de información de los recursos de la red.

Gestión del Rendimiento — Monitorear y medir diversos aspectos de las métricas de rendimiento (tiempo de respuesta, utilización del enlace y tasas de error).

Gestión de la Seguridad — Proporcionar acceso a los dispositivos de red y a los recursos de la empresa a personas autorizadas. Enfocada en la autenticación, autorización, firewalls, segmentación de red, IDS y notificaciones de intentos de violaciones de seguridad.

LOCAL AREA NETWORK - LAN

COMPONENTES

Repetidores (repeaters): Dispositivos de capa física, reciben señales de un segmento de red y amplifican la señal durante la transmisión.

Concentradores (hubs): Dispositivos de capa física – Concentradores de red.

Bridges: Dispositivos de capa de enlace, actúan como equipos de almacenamiento y reenvío de tramas (frames) hacia su destino.

Switches de capa 2: Dispositivos a nivel de enlace de datos, divide e interconectan segmentos, reducen los dominios de colisión en las redes basadas en Ethernet.

Enrutadores (routers): Operan en la capa de red, toman decisiones inteligentes para dirigir el paquete a su destino.

SEGURIDAD LAN /WAN

- Susceptible a amenazas relacionadas con las personas y los virus, debido a la gran cantidad de las personas que tienen derechos de acceso.
- Las funciones administrativas y de control disponibles con el software de la red pueden ser limitadas.

REDES DE ÁREA LOCAL INALÁMBRICAS (WLAN)

SEGURIDAD DE LA RED

- ❖ WLAN incluye 802.11, HyperLAN, HomeRF
- ❖ Los dispositivos de punto de acceso suelen tener áreas de cobertura (también conocidos como celda o rango) de hasta 300 pies (aproximadamente 100 metros).

WIRED EQUIVALENT PRIVACY (PRIVACIDAD EQUIVALENTE AL USO DE CABLES) Y ACCESO PROTEGIDO A WI-FI (WPA/WPA2)

- ☐ WEP => IEEE 802.11. Utiliza claves simétricas.
- ☐ (WPA), Wi-Fi Protected Access
- ☐ WPA2) => 802.11i

PUERTOS Y PROTOCOLOS

Un puerto es una forma de identificar el proceso específico al que un mensaje de Internet u otra red será dirigido cuando llegue a un servidor.

Puerto	Servicio	Protocolo	Puerto	Servicio	Protocolo
7	Echo	TCP/UDP	110	POP3 (protocolo de oficina postal)	TCP
19	chargen	TCP	111/2049	SunRPC (llamadas de procedimientos remotos)	TCP/UDP
20-21	FTP (Protocolo de transferencia de archivos)	TCP	135-139	NBT (NetBIOS sobre TCP/ IP)	TCP/UDP
23	Telnet (Inicio de sesión remoto)	TCP	161, 162	SNMP (Protocolo de Gestión de Redes Simple)	UDP
25	SMTP (Protocolo simple de Transporte de correos)	TCP	512	Exec	UDP
43	Whois	TCP/UDP	513	Login	TCP
53	DNS (Sistemas de nombres de dominio)	TCP	514	Shell	TCP/UDP
69	TFTP (Protocolo de transferencia de archivos trivial)	TCP/UDP	6000-xxxx	X-Windows	TCP/UDP
79	Finger	TCP	8000	HTTP	TCP/UDP
80	HTTP-low	TCP	8080	HTTP	TCP/UDP
107	Rtelnnet	TCP/UDP	31337	Back Orifice	UDP

La tunelización (tunneling) es el proceso de encapsular un tipo de protocolo en otro.
REDES PRIVADAS VIRTUALES

Tipos comunes de tunelización.

Protocolo de túnel punto a punto (PPTP) – Protocolo de capa 2. Encapsula datos de protocolo punto a punto.

Protocolo de túnel de Capa 2 (L2TP) - Encapsula los datos del protocolo de punto a punto y es compatible entre equipos de diferentes fabricantes.

VOZ POR PROTOCOLO DE INTERNET (VoIP)

Cualquier dispositivo VoIP es un dispositivo IP; por tanto, es vulnerable a los mismos tipos de ataques que cualquier otro dispositivo IP.

- ❖ Virus
- ❖ Captura de paquetes > Escaneo de puertos – precursor.
- ❖ Ataques de denegación de servicio – Revisión QoS.
- ❖ Interrupción del flujo de tráfico.
- ❖ Fraude telefónico.

Los paquetes de voz viajan **“en claro”** -> RTP de voz viajan en claro por la red y podrían ser capturados o copiados.

SEGURIDAD DEL SISTEMA OPERATIVO

La mayoría de los proveedores de computadores dejan abiertos los controles predeterminados, favoreciendo la facilidad de uso por encima de la seguridad.

Controles comunes

- ☐ Autenticación y autorización
- ☐ Permisos del sistema de archivos
- ☐ Privilegios de acceso
- ☐ Monitorización de registro y del sistema
- ☐ Servicios del sistema

El fortalecimiento del sistema debe aplicar el principio de privilegios mínimos o control de acceso.

SEGURIDAD DEL SISTEMA OPERATIVO

MODO DE OPERACIONES

Modo Kernel: Ejecución de instrucciones privilegiadas.

Modo Usuario: Actividades normales.



La mayoría de los ataques buscan ganar acceso privilegiado o acceso en modo kernel al sistema, con el fin de eludir otros controles de seguridad.

FORTALECIMIENTO DE LA PLATAFORMA

Windows diferencia entre archivos y dispositivos tales como impresoras, mientras que en UNIX se considera como archivo, lo cual incluye los dispositivos físicos.

Identificar la localización de la información crítica es imprescindible, no sólo para la seguridad, sino también para la respuesta a incidentes.

SISTEMAS UNIX

- ❑ `/etc/passwd` - Mantiene información de cuentas de usuario y contraseñas.
- ❑ `/etc/shadow` - Conserva la contraseña cifrada de la cuenta correspondiente.
- ❑ `/etc/group` - Contiene información de grupo para cada cuenta.
- ❑ `/etc/gshadow` - Contiene información segura de los grupos de cuentas.
- ❑ `/bin` - Ubicación de los archivos ejecutables.
- ❑ `/boot` - Contiene los archivos de arranque del sistema.
- ❑ `/kernel` - Archivos kernel.
- ❑ `/sbin` - Archivos ejecutables (Administración).

SISTEMAS WINDOWS

- `HKEY_CURRENT_CONFIG` - Contiene información volátil generada en el arranque.
- `HKEY_CURRENT_USER` - Ajustes específicos del usuario actual.
- `HKEY_LOCAL_MACHINE\SAM` - Información local y de las cuentas de dominio.
- `HKEY_LOCAL_MACHINE\Security` - Contiene la política de seguridad referenciada y forzada por el kernel.
- `HKEY_LOCAL_MACHINE\Software` - Ajustes de software y Windows.
- `HKEY_LOCAL_MACHINE\System` - Información sobre la configuración de Windows.

CONOCIMIENTO DE LINEAS DE COMANDOS

Profesionales utilizan herramientas de línea de comandos como parte de su rutina de seguridad.

- **Nmap** - Escáner de puertos de red
- **Metasploit** - Pruebas de penetración
- **Aircrack-ng** - Rompimiento de claves 802.11 WEP y WPA-PSK
- **Snort®**- Código abierto IDS/IPS
- **Netstat** - Información detallada del estado de la red
- **Netcat** – Lee y escribe datos a través de conexiones de red, utilizando el protocolo TCP / IP
- **Tcpdump** – Analizador de paquetes de línea de comandos
- **John the Ripper** – Rompimiento de contraseñas
- **Kismet** - Detector de red inalámbrica de capa 2 802.11, sniffer e IDS
- **OpenSSH/PuTTY/SSH** - Iniciar sesión o ejecutar comandos en una máquina remota.

Comando	Descripción
finger {userid}	Mostrar información de un usuario
cat	Mostrar o concatenar archivos
cd	Cambiar de directorio
chmod	Cambia los permisos de un archivo Nota: Los permisos de UNIX se administran mediante la notación octal por usuario, grupo y otros. La manipulación de los permisos está por encima del objetivo de este material, pero son críticos conforme avance en su carrera de ciberseguridad.
cp	Copiar
date	Mostrar fecha y hora actual
diff	Mostrar diferencias entre archivos de texto
grep	Encontrar cadena de caracteres en un archivo
ls	Lista de directorio: Ajustes útiles: -a Mostrar todos los archivos* -d Mostrar sólo los directorios -l Mostrar listado largo -u Mostrar archivos por su acceso (el más reciente primero) -U Mostrar los resultados por creación (el más reciente primero) Nota: A diferencia de Windows, Unix no ofrece la oportunidad de "dejar visibles" los archivos ocultos. Identificados como "archivos de puntos" (del inglés "dot files"), los nombres de estos archivos comienzan con un ".", después viene el nombre. Para ver estos archivos protegidos del sistema, se debe utilizar el ajuste -a. [ls -a ó ls -al]
man	Mostrar ayuda
mkdir	Crear un directorio
mv	Mover / Renombrar archivo
ps	Mostrar procesos activos
pwd	Mostrar el directorio actual
rm	Borrar archivo
rmdir	Borrar directorio
sort	Ordenar los datos
whoami	Muestra con qué nombre de usuario se está conectado

REGISTRO Y MONITOREO DEL SISTEMA

Proporciona datos básicos necesarios para monitorear y detectar actividad no autorizada, y analizar posibles brechas de seguridad.

SIEM -> "Security Incident and Event Management")

Eventos de seguridad  Errores de autenticación
Registro de acceso a archivos críticos del sistema

Determinar exactamente qué y cuánto registrar requiere una consideración cuidadosa.

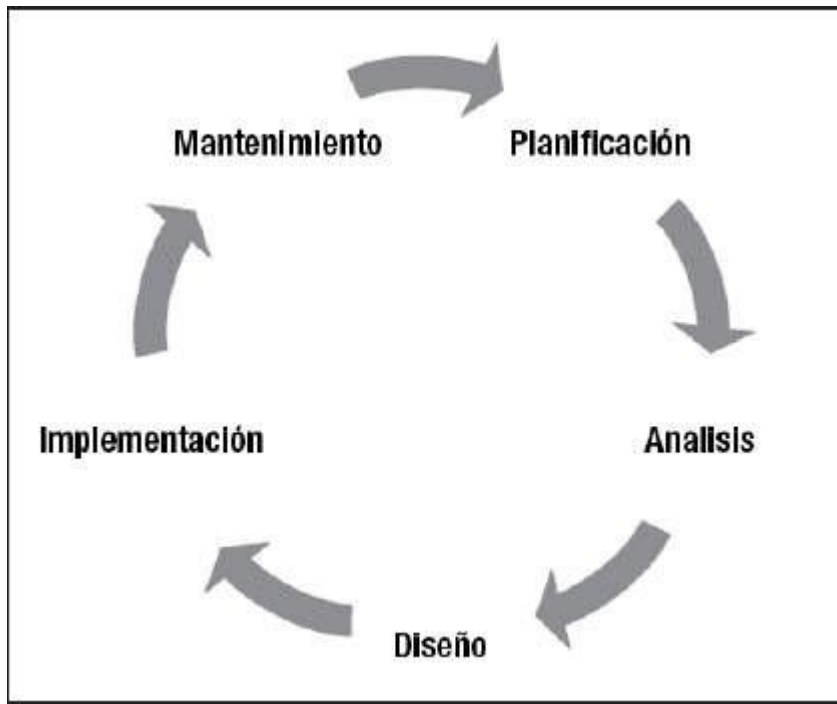
VIRTUALIZACIÓN

- ☐ Aumenta la eficiencia y disminuye los costos en sus operaciones de TI
- ☐ Múltiples sistemas operativos coexistan en el mismo servidor físico

Ventajas	Desventajas
• Los costes de hardware en servidores pueden disminuir, tanto para la implementación de servidores como para su mantenimiento. • Varios sistemas operativos pueden compartir la capacidad de procesamiento y espacio de almacenamiento, que a menudo se desperdicia en los servidores tradicionales, reduciendo así los costos de operación. • El impacto ecológico de los servidores puede disminuir, en el centro de procesamiento de datos. • Un único anfitrión puede tener varias versiones del mismo sistema operativo, o incluso diferentes sistemas operativos, para facilitar las pruebas de las aplicaciones por diferencias de rendimiento. • La creación de copias duplicadas de los huéspedes en ubicaciones alternativas, puede dar soporte a los esfuerzos de continuidad del negocio. • El personal de soporte de aplicaciones puede tener múltiples versiones del mismo sistema operativo, o incluso diferentes sistemas operativos, en un solo host, para dar apoyo con mayor facilidad a los usuarios que operan en diferentes ambientes. • Una sola máquina puede albergar a una red multicapa en un entorno de laboratorio con fines educativos, sin reconfiguraciones costosas de equipo físico. • Las organizaciones más pequeñas que han realizado pruebas en el entorno de producción, pueden estar en mejores condiciones de establecer entornos separados de desarrollo y de pruebas, de forma económica. • Si se configura correctamente, un control de acceso único bien implementado en el host, puede proporcionar un control más estricto para varios huéspedes.	• La configuración inadecuada del host podría crear vulnerabilidades que afectan no sólo al host, sino también a los huéspedes. • La explotación de vulnerabilidades dentro de la configuración del host o un ataque DoS contra el host, podrían afectar a todos los huéspedes del host. • Un compromiso de la consola de administración podría conceder acceso administrativo no autorizado a los huéspedes del host. • Problemas de rendimiento del sistema operativo propio del host, podrían afectar a cada uno de los huéspedes del host. • Los datos podrían filtrarse entre los huéspedes, si la memoria no se libera y se asigna por el anfitrión, de una manera controlada. • Los protocolos inseguros para el acceso remoto a la consola de administración y los huéspedes, pueden llevar a una exposición de las credenciales administrativas.

Utilizar código no autorizado en aplicaciones inseguras puede permitir a una atacante acceder, robar, modificar o eliminar información confidencial.

CICLO DE VIDA DEL DESARROLLO DE SISTEMAS SDLC



Incluye:

- ❖ Procesos de TI para gestión y control de la actividad del proyecto.
- ❖ Objetivo para cada fase del ciclo de vida (resultados, descripción de tareas, resumen de objetivos de control).
- ❖ Entregables.

Requisitos de diseño:

- ❖ Requisitos de negocio.
- ❖ Requisitos funcionales.
- ❖ Requisitos técnicos.
- ❖ Requisitos de mitigación y control de riesgos.

La seguridad y mitigación de riesgos deberían ser criterios formales de diseño en cualquier proceso de SDLC

Vector de Ataque	Descripción del Riesgo de Seguridad
Inyección	Los fallos de inyección ocurren cuando los datos que no son de confianza, se envían a un intérprete. El atacante puede engañar al intérprete para que ejecute comandos involuntariamente o acceder a datos no autorizados. Los fallos de inyección son frecuentes y, a menudo se encuentran en las consultas SQL y LDAP, así como en comandos del sistema operativo.
Ruptura de la autenticación y gestión de la sesión	Si una función de aplicación relacionada con la autenticación o gestión de sesiones no se implementa correctamente, puede permitir a un usuario malintencionado poner en peligro las contraseñas, claves o tokens de sesión y suplantar a los usuarios legítimos.
Cross-Site Scripting (XSS)	Los fallos XSS ocurren cuando una aplicación toma datos que no son de confianza y los envía a un navegador web sin la validación adecuada. Esto es el fallo más frecuente de seguridad de aplicaciones web. Los atacantes pueden utilizar XSS para secuestrar sesiones de usuario, insertar contenido hostil, desconfigurar sitios web y redirigir a los usuarios.
Referencias directas a objetos inseguras	Una referencia directa a un objeto se produce cuando un desarrollador <u>expone una referencia a un objeto de implementación interna</u> . Los atacantes pueden manipular estas referencias para acceder a datos no autorizados.
Mala configuración de seguridad	Configuraciones de seguridad se deben definir, implementar y mantener en aplicaciones, marcos, servidores de aplicaciones, servidores web, servidores de bases de datos y plataformas. Una mala configuración de seguridad puede dar a los atacantes el <u>acceso no autorizado a los datos o la funcionalidad del sistema</u> .
Exposición de datos confidenciales	Si las aplicaciones web no garantizan adecuadamente los datos sensibles a través del uso de <u>cifrado</u> , los atacantes pueden robar o modificar los datos sensibles, tales como los registros de salud, tarjetas de crédito, identificaciones fiscales y las credenciales de autenticación.
Falta de control de acceso a nivel de función	Cuando no se verifican los derechos de acceso de nivel de la función, los atacantes pueden <u>falsificar las solicitudes para acceder a la funcionalidad sin autorización</u> .
Falsificación de petición en sitios cruzados (CSRF, Cross-Site Request Forgery)	Un ataque CSRF se produce cuando un atacante obliga al navegador del usuario a <u>enviar peticiones HTTP falsificadas</u> , incluyendo las "cookies" de sesión. Esto permite a un atacante engañar a las víctimas para realizar operaciones en sitios web ilegítimos.
Uso de componentes con vulnerabilidades conocidas	Ciertos componentes, tales como bibliotecas, marcos y otros módulos de software generalmente se ejecutan con privilegios completos. Los atacantes pueden explotar un componente vulnerable para acceder a datos o hacerse cargo de un servidor.
Redireccionamientos y reenvíos no validados	Las aplicaciones Web con frecuencia re-direccionan o re-envían a los usuarios a otras páginas. Cuando se utilizan datos no confiables para determinar el destino, un atacante puede redirigir las víctimas a sitios de phishing o malware.

SEGURIDAD DE LAS APLICACIONES

CONTROLES DE APLICACIÓN

- ❖ Firewall
- ❖ Programas de cifrado
- ❖ Programas contra software malintencionado (anti-malware)
- ❖ Programas de detección/eliminación de spyware
- ❖ Autenticación biométrica

Controles automatizados deben ir acompañados de procedimientos manuales para asegurar la debida investigación de las excepciones.

Recomendaciones para reducir riesgos de seguridad en aplicaciones – OWASP.

- Definir los requisitos de seguridad de la aplicación
- Utilizar buenas prácticas de arquitectura de seguridad de la aplicación desde el principio del diseño de la aplicación
- Implementar controles de seguridad fuertes y utilizables
- Integrar la seguridad en el ciclo de vida de desarrollo
- Permanecer actualizado en las vulnerabilidades de las aplicaciones

AMENAZAS ADICIONALES

SEGURIDAD DE LAS APLICACIONES

Canal encubierto: Transferir ilícitamente información.

Condición de carrera: “Una situación indeseable se produce cuando un dispositivo o sistema intenta realizar dos o más operaciones, al mismo tiempo, pero debido a la naturaleza del dispositivo o sistema, las operaciones deben realizarse en la secuencia correcta con el fin de hacerse correctamente”.

Ataque orientado a retorno: Técnica para explotar las vulnerabilidades de corrupción de memoria. Ejecución de código sobre las pilas (**stacks**) no ejecutables y montículos (**heaps**) no ejecutables.

Las vulnerabilidades de corrupción de memoria se producen “cuando un programa privilegiado está obligado a corromper su propio espacio de memoria”.

CONTROLES A NIVEL DE BASE DE DATOS

SEGURIDAD DE DATOS

- ☐ Autenticación y autorización de acceso
- ☐ Controles de acceso (sólo lectura, lectura y escritura, o borrado)
- ☐ Monitoreo de registro y otras transacciones
- ☐ Controles de cifrado e integridad
- ☐ Copias de seguridad

CLASIFICACIÓN DE DATOS

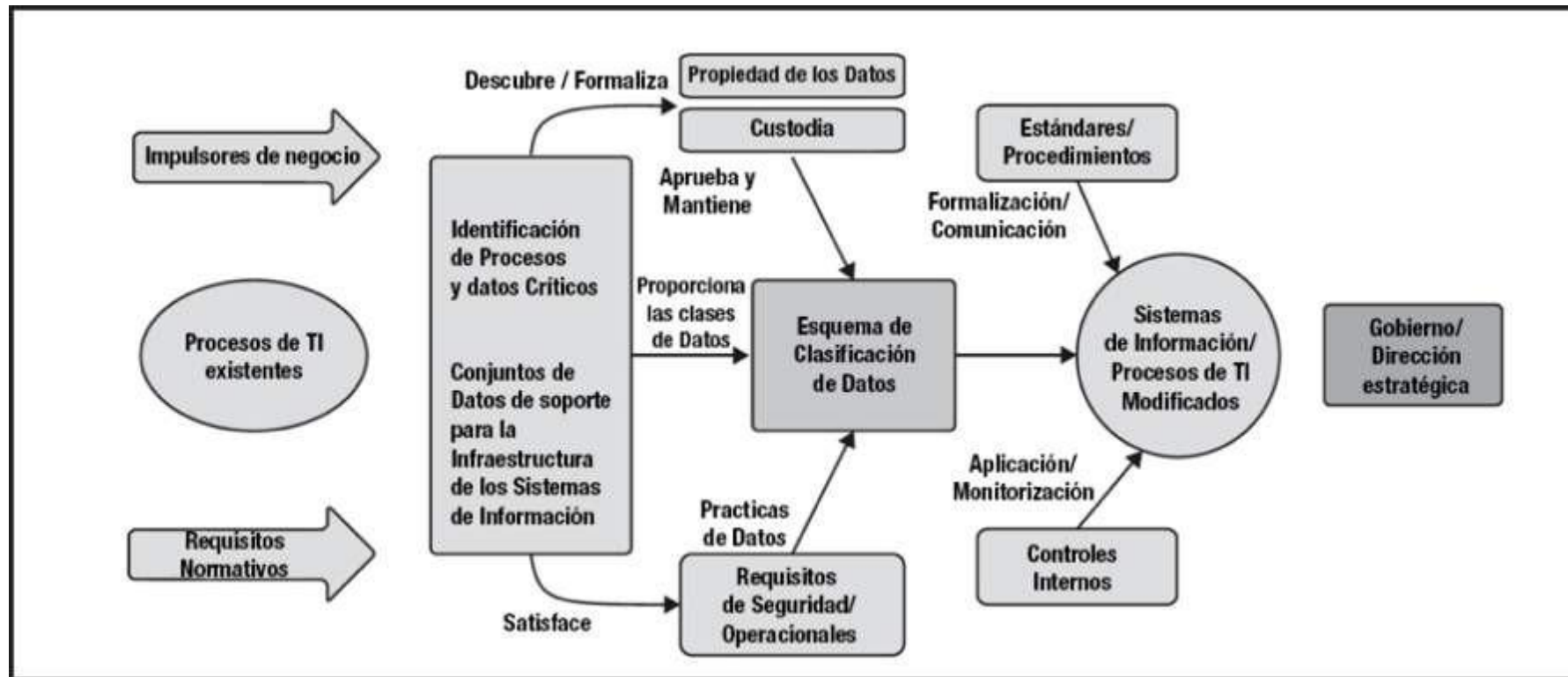
Es importante que la organización comprenda la sensibilidad de la información y clasifique los datos en función de su confidencialidad y el impacto de la publicación o pérdida de la información.

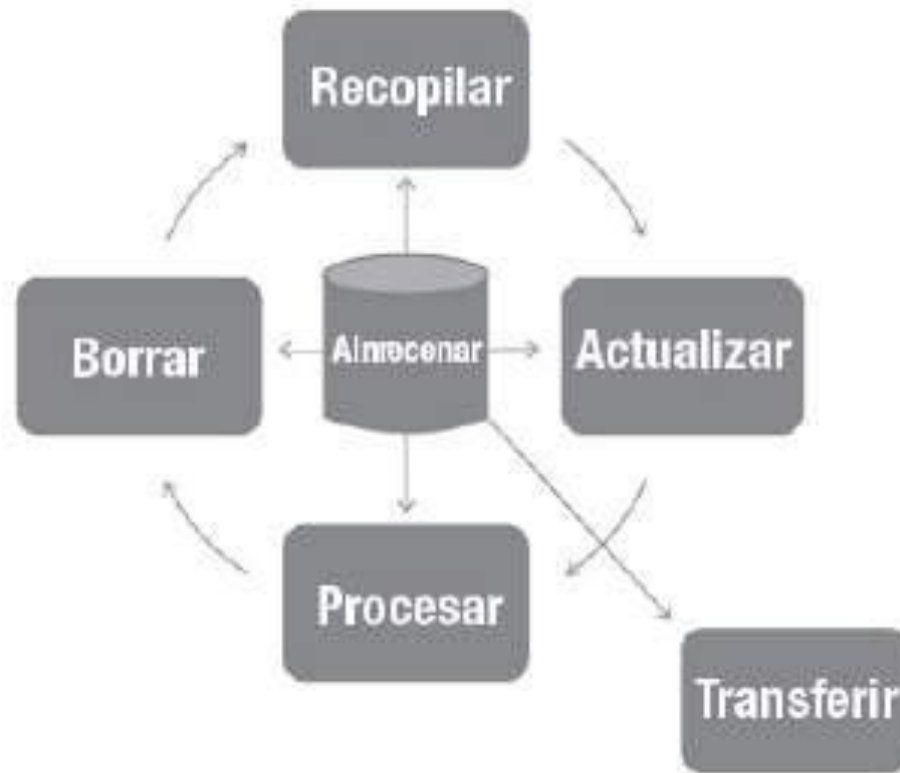
- ❖ Etiquetado de datos
- ❖ Política de clasificación de datos.
- ❖ Regulaciones. Ley Sarbanes-Oxley - Define qué registros de datos deben almacenarse y por cuánto tiempo.
- ❖ La información también puede necesitar ser reclasificada en base a los cambios en su importancia.

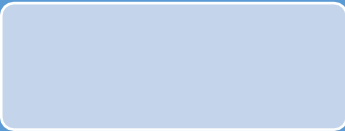
PROPIETARIOS DE LOS DATOS

- Definir el propietario de los datos
- Los datos no pertenecen a TI.
- La información del negocio pertenece en última instancia al responsable de los procesos del negocio.

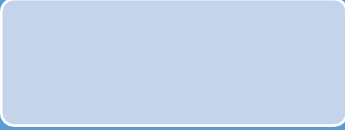
PROCESO DE CLASIFICACIÓN DE DATOS







1. INTRODUCCIÓN Y VISIÓN GENERAL DE LA CIBERSEGURIDAD



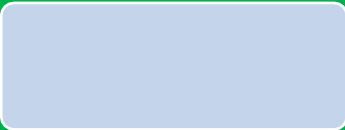
2. CONCEPTOS DE LA CIBERSEGURIDAD



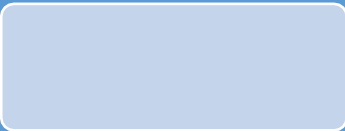
3. PRINCIPIOS DE ARQUITECTURA DE SEGURIDAD



4. SEGURIDAD DE REDES, SISTEMAS, APLICACIONES Y DATOS



5. RESPUESTA A INCIDENTES



6. IMPLICACIONES DE SEGURIDAD Y ADOPCIÓN DE LA TECNOLOGÍA

EVENTO VS. INCIDENTE

EVENTO VS. INCIDENTE

EVENTO: Cualquier cambio, error o interrupción dentro de una infraestructura de TI como un fallo del sistema, un error de disco o un usuario que olvide su contraseña.

NIST -> "cualquier ocurrencia observable en un sistema o red."

INCIDENTE: Violación o una amenaza inminente de violación de las políticas de seguridad informática, políticas de uso aceptable o prácticas de seguridad estándar."

Es **importante** distinguir entre los **eventos** que se manejan en el curso normal de los negocios y los **incidentes** que requieren la experiencia en seguridad e investigación para gestionarlos.

TIPOS DE INCIDENTES

Incidente de ciberseguridad: Evento adverso que afecta negativamente a la confidencialidad, integridad y disponibilidad de los datos. Pueden ser de tipo:

- ❖ Involuntarios
- ❖ Intencionales
- ❖ Técnicos (malware, virus, ataques DoS, fallos del sistema)
- ❖ Físicos (Ingeniería social, pérdida o robo de ordenadores o dispositivos móviles).

Figura 5.1: Incidentes de Seguridad y Plazos de Presentación de Informes

Categoría	Nombre	Descripción	Plazos de Presentación de Informes
CAT 1	Acceso no autorizado	Un individuo obtiene acceso lógico o físico sin permiso a una red, sistemas, aplicaciones, datos u otro recurso	Dentro de 1 hora del descubrimiento/detección
CAT 2	Denegación del servicio (DoS)	Un ataque que con éxito impide o perjudica la funcionalidad normal autorizada de redes, sistemas o aplicaciones por agotamiento de recursos	Dentro de dos horas del descubrimiento o detección si el ataque exitoso continúa
CAT 3	Código malicioso	La instalación exitosa de software malicioso (por ejemplo, virus , gusano, troyanos u otra entidad maliciosa basada en código) que infecta un sistema operativo o aplicación	Diariamente; dentro de una hora del descubrimiento o detección si se extiende
CAT 4	Uso impropio	Una persona viola las políticas aceptables de uso de los ordenadores	Semanalmente
CAT 5	Escáneres/ Sondas/Intentos de acceso	Cualquier actividad que pretende acceder o identificar un ordenador, puertos abiertos , protocolos , servicios o cualquier combinación	Mensualmente
CAT 6	Investigación	Incidentes sin confirmar que son actividades potencialmente maliciosas o anómalas	N/A



¿QUE ES LA RESPUESTA A INCIDENTES? Programa que prepara a una entidad para un incidente.

FASES

- 1. Preparación:** Establecer roles, responsabilidades y planes para el manejo de un incidente.
- 2. Detección y análisis:** Identificar y evaluar incidentes.
- 3. Investigación Identificación de un adversario.**
- 4. Mitigación y recuperación:** Contener el incidente, reducir las pérdidas y volver las operaciones a la normalidad.
- 5. Análisis posterior al incidente:** Determinar acciones correctivas para prevenir incidentes similares en el futuro.

¿PORQUÉ NECESITAMOS RESPUESTA A INCIDENTES?

Una planificación e implementación adecuada de la respuesta a incidentes permite a una organización responder a un incidente de una manera sistemática, eficaz y oportuna.

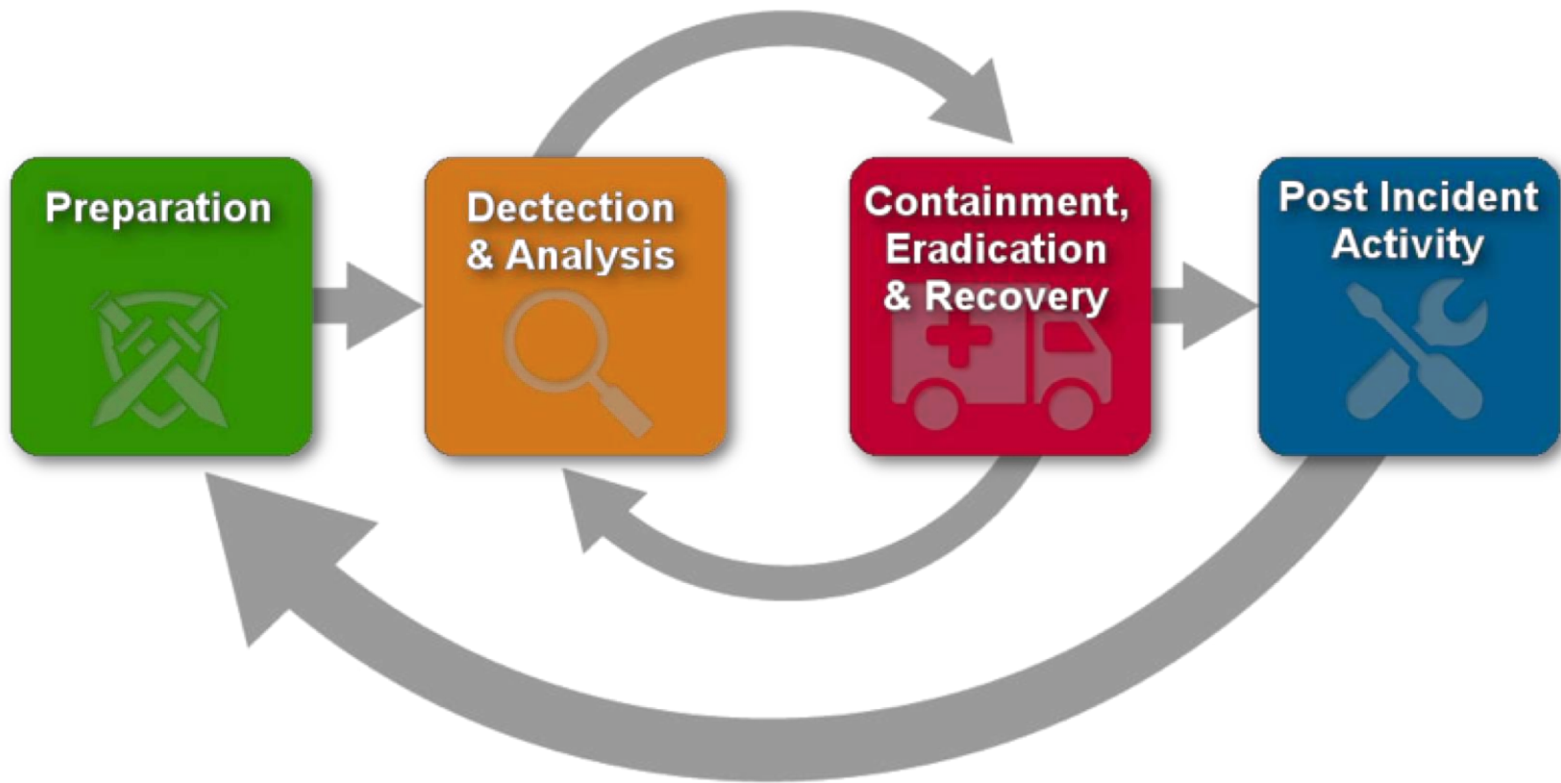
Regulaciones de cumplimiento como la Industria de Tarjeta de Pago (PCI) y la Corporación Federal de Seguro de Depósitos (FDIC) proporcionan requisitos estrictos para las políticas de seguridad y la planificación de respuesta a incidentes.

ELEMENTOS DE UN PLAN DE RESPUESTA A INCIDENTES

Preparación — Desarrollo de un plan de respuesta a incidentes antes de un incidente.

Actividades

- ☐ Establecer un enfoque para manejar incidentes.
- ☐ Establecer la política y banners de advertencia.
- ☐ Establecer un plan de comunicación para las partes interesadas.
- ☐ Desarrollar criterios sobre cuándo reportar un incidente a las autoridades.
- ☐ Desarrollar un proceso para activar el equipo de gestión de incidentes.
- ☐ Establecer un lugar seguro para ejecutar el plan de respuesta a incidentes.
- ☐ Asegurar que el equipo necesario este disponible.



GESTIÓN DE EVENTOS DE SEGURIDAD

RESPUESTA A INCIDENTES.

Los incidentes de seguridad a menudo están compuestos por una serie de eventos que se producen en toda una red.

- ❖ Gestión de eventos de seguridad (SEM).
- ❖ Correlaciones basadas en reglas.
- ❖ Patrón de eventos.
- ❖ Algoritmos para calcular los niveles de amenaza.

Los sistemas de gestión de incidentes y eventos de seguridad (SIEM) toman las capacidades de los SEM y las combinan con las características de análisis histórico y los informes de los sistemas de gestión de la información de seguridad (SIM).

INVESTIGACIONES, RETENCIONES LEGALES Y PRESERVACIÓN

INVESTIGACIONES: Incluyen la recopilación y análisis de las evidencias con el objetivo de identificar al autor de un ataque o del uso o acceso no autorizado.

Análisis técnico utilizado en la respuesta a incidentes donde el objetivo es entender la naturaleza del ataque, lo que sucedió y cómo ocurrió.

PRESERVACIÓN DE EVIDENCIAS

La evidencia pierde su integridad y valor legal en los procesos judiciales si no se ha preservado y está sujeta a una cadena documentada de custodia. Esto sucede cuando el incidente se gestiona de forma inapropiada y se responde a él de manera ad hoc.

La Cadena de custodia contiene información sobre:

- Quién tuvo acceso a la evidencia (de manera cronológica)
- Procedimientos seguidos al trabajar con la evidencia (duplicación de discos, volcado de memoria virtual)
- Prueba que el análisis se basa en copias que son idénticas a la evidencia original.

La evidencia de un delito informático.

La capacidad de localizar y capturar la evidencia depende del tipo de datos, habilidades y experiencia de los investigadores, y las herramientas.

RESPUESTA A INCIDENTES.

PRESERVACIÓN DE EVIDENCIAS

- Reiniciar el sistema o acceder a los archivos podría dar lugar a que las pruebas se pierdan.
- Cualquier análisis adicional debe ser realizado en una imagen del sistema y en las copias de la memoria – no en el sistema original en cuestión.

La cadena de custodia es un término que se refiere a la documentación, en detalle, cómo se maneja y mantiene la evidencia, incluyendo su propiedad, transferencia y modificación.



ANÁLISIS FORENSE

Proceso de **identificar, preservar, analizar y presentar la evidencia digital** de una manera que sea legalmente aceptable en cualquier procedimiento legal.

Implica la exploración y aplicación de métodos para recopilar, procesar, interpretar y utilizar la evidencia digital que ayudan a corroborar si un incidente ocurrió y recaba evidencia digital que después podrá ser utilizada en los procesos judiciales

Es importante demostrar la integridad y confiabilidad de la evidencia.

CONSIDERACIONES

Identificar: Identificación de la **información** que **está disponible**.

Preservar: Práctica de **recuperación de información identificada** y que se preserva como evidencia.

Analizar: Extracción, procesamiento e **interpretación de las evidencias**.

Presentar: Presentación a las diferencias audiencias como **gerentes, abogados, tribunales**.



PROTECCIÓN DE DATOS

RESPUESTA A INCIDENTES.

- ☐ Evitar que la información buscada sea alterada.
- ☐ Es importante establecer protocolos específicos para informar a las partes apropiadas que buscarán pruebas electrónicas y no destruirlas por cualquier medio.

ADQUISICIÓN DE DATOS

- Toda la información y los datos requeridos deben ser transferidos a una ubicación controlada.
- Cada dispositivo debe ser revisado para asegurar que está protegido contra escritura (bloqueador de escritura).

Obtención de datos

- Datos volátiles, puertos abiertos.
- Archivos abiertos.
- Procesos activos.
- Inicio de sesión de usuario.
- Datos presentes en la memoria RAM.

GENERACIÓN DE IMÁGENES

Proceso que permite obtener una copia bit a bit de datos para evitar el daño de datos o información originales cuando se pueden realizar múltiples análisis.

Objetivo: Obtener datos residuales (archivos borrados, fragmentos de archivos borrados e información presente del disco para su análisis).

RESPUESTA A INCIDENTES.

EXTRACCIÓN

- Identificación y **selección de los datos** del conjunto de datos copiados.
- Este proceso incluye **estándares de calidad, integridad y confiabilidad**, software utilizado, registros del sistema, registros del firewall, registros del IDS, pistas de auditoría y la información de gestión de red.

INTERROGATORIO: Obtener indicadores o relaciones anteriores, incluyendo **números de teléfono, direcciones IP y los nombres de las personas, a partir de datos extraídos.**

CONVERSIÓN DE DATOS A TEXTO CLARO / NORMALIZACIÓN

Convierte la información extraída a un **formato** que puede ser entendido por los investigadores. (Datos hexadecimales o binarios en caracteres legibles).

Técnicas: Fusión, correlación, graficado, mapeo o cronológico.

RESPUESTA A INCIDENTES.

PRESENTACION DE INFORMES: Un informe debe indicar por qué se revisó el sistema, cómo se revisaron los datos del ordenador y qué conclusiones se hicieron a partir de este análisis.

Objetivos a Alcanzar.

- Describir con precisión los **detalles de un incidente**.
- Ser **comprensible** para los encargados de tomar decisiones.
- Soportar un aluvión de **escrutinio legal**.
- Ser **inequívoca** y no estar abierto a una interpretación errónea.
- Ser **fácilmente referenciado**.
- Contener toda la información necesaria para **explicar las conclusiones alcanzadas**.
- **Conclusiones**, opiniones o recomendaciones.
- Ser creado en el **momento oportuno**.

RESPUESTA A INCIDENTES.

ANÁLISIS DE ARCHIVOS DE REGISTRO

Con herramientas automatizadas se puede diferenciar los datos de seguimiento de auditoría que no son utilizados y realizan un examen eficaz.

- **Herramientas de reducción de auditoría:** Preprocesadores diseñados para **reducir el volumen de registros de auditoría para facilitar la revisión manual**. Pueden eliminar muchos registros de auditoría que tienen poca importancia para la seguridad, eliminan registros generados de eventos (registros por copias de seguridad nocturnas).
- **Herramientas de detección de tendencia/varianza:** Buscan **anomalías en el comportamiento del usuario o del sistema**. (si un usuario inicia una sesión normalmente a las 09:00, pero aparece a las 04:30 una mañana, puede asociarse a un problema de seguridad).
- **Herramientas de detección de firma de ataques:** Buscan una firma de ataque **Secuencia específica de eventos**. Ejemplo: Intentos de inicio de sesión fallidos.

HERRAMIENTAS DE ANÁLISIS FORENSE DIGITAL

RESPUESTA A INCIDENTES.

Categorías

Ordenador > Examina los medios digitales no volátiles en diferentes plataformas (Windows, Linux).

- Herramientas de código abierto.
- Algunos se limitan al cumplimiento de la ley y/o las agencias gubernamentales.
- Los requerimientos del negocio determinarán la selección.

Memoria —Adquirir y analizar la memoria volátil.

Dispositivo móvil —Componentes de software y hardware.

Red —Monitoreo y análisis del tráfico de red.

- > Wireshark®: Analizador de paquetes de código abierto gratuito.
- > VMware®: Aplicaciones de soporte.

LINEAS DE TIEMPO

- ☐ Gráficos cronológicos donde los acontecimientos pueden ser mapeados.
- ☐ Proporcionan una visualización simplificada.

ANTI ANÁLISIS FORENSE

RESPUESTA A INCIDENTES.

Las herramientas anti-análisis forense dificultan la labor de los investigadores para recuperar información durante una investigación.

Tácticas, técnicas y procedimientos (TTP) anti-forenses incluyen, aunque no están limitados a:

- ☐ Borrar de forma segura los datos.
- ☐ Sobrescribir metadatos.
- ☐ Prevenir la creación de datos.
- ☐ Cifrado de datos.
- ☐ Cifrado protocolos de red.
- ☐ Ocultar datos en el espacio de inactividad o en otros lugares no asignados.



¿QUÉ ES UN DESASTRE?

Disrupciones que causan que los recursos de información críticos no estén operativos durante un período de tiempo, afectando negativamente las operaciones de la organización.

- Requieren esfuerzos de recuperación para restaurar el estado de funcionamiento.

Un desastre puede ser causado por:

- ❖ Desastres naturales (terremotos, inundaciones, tornados e incendios).
- ❖ Eventos provocados por los seres humanos, (atentados terroristas, ataques de hackers, virus o errores humanos).

- ☐ Muchas interrupciones comienzan como simples incidentes.
- ☐ Una mesa de ayuda o centro de servicios actúa como el sistema de alerta temprana.

Desastres relacionados con la ciberseguridad pueden ocurrir cuando una interrupción en el servicio se debe a un mal funcionamiento del sistema, la eliminación accidental de archivos, el lanzamiento de aplicaciones no probadas, la pérdida de copias de seguridad, ataques de denegación de servicio, intrusiones o virus.

Las acciones pueden requerir la restauración de hardware, software o archivos de datos.

RECUPERACIÓN DE DESASTRES Y PLANES DE CONTINUIDAD DEL NEGOCIO.

CONTINUIDAD DE NEGOCIO Y RECUPERACIÓN DE DESASTRES

- El **BCP** es responsabilidad de la alta dirección, ya que se encarga de la protección de los activos y la viabilidad de la organización.
- El **BCP** es seguido por las unidades de negocio y de apoyo, para proporcionar un **nivel reducido pero suficiente de funcionalidad** en las operaciones después de encontrarse con una interrupción.

Dependiendo de la complejidad de la organización, puede haber uno o más planes para abordar los diversos aspectos del BCP y del DRP. Cada uno tiene que ser coherente con los otros planes para tener una estrategia viable de BCP.

Las soluciones del BCP y del DRP pueden ser diferentes para diferentes escenarios debido a los requisitos contractuales.



ANÁLISIS DE IMPACTO EN EL NEGOCIO

El primer paso en la preparación de un nuevo BCP es identificar los procesos de negocio de importancia estratégica - aquellos procesos claves que son responsables tanto del crecimiento permanente del negocio como del cumplimiento de los objetivos de negocio.

Un proceso de análisis de impacto en el negocio (BIA) debe comenzar determinando **plazos, prioridades, recursos e interdependencias que apoyan los procesos clave**.

El **riesgo** del negocio es **directamente proporcional al impacto en la organización y la probabilidad** de ocurrencia de la amenaza percibida.

El **BIA** debe identificar:

- ❖ **Recursos humanos, datos, elementos de infraestructura** y otros recursos (incluyendo terceros).
- ❖ Lista de **vulnerabilidades** potenciales.
- ❖ **Probabilidad** estimada de ocurrencia de amenazas.
- ❖ **Eficiencia y eficacia de los controles** de mitigación de riesgos existentes.

RECUPERACIÓN DE DESASTRES Y PLANES DE CONTINUIDAD DEL NEGOCIO.

Para evaluar el impacto del tiempo de inactividad de un proceso/aplicación, se desarrolla **bandas de impacto** (alta, media, baja), y para cada proceso, **el impacto se estima en tiempo** (horas, días, semanas).

El BIA debe responder a tres preguntas importantes:

1. ¿Cuáles son los diferentes procesos de negocio?
2. ¿Cuáles son los recursos de información críticos relacionados con los procesos de negocio críticos?
3. ¿Cuál es el período de tiempo de recuperación crítico para los recursos de información antes de que se sufran pérdidas significativas o pérdidas inaceptables?

CONSIDERACIÓN EN LA CADENA DE SUMINISTRO

La NIST define la cadena de suministro de la tecnología de la información y comunicación (ICT) como "un ecosistema complejo, distribuido a nivel mundial e interconectado, que tiene diversas rutas geográficas, y se compone de múltiples niveles de externalización."

La complejidad de las cadenas de suministro y el impacto requiere una concienciación persistente de riesgo y consideración.

Factores que contribuyen a la fragilidad de las cadenas de suministro: -> Económicos
-> Ambientales
-> Geopolíticos
-> Tecnológicos.

La cadena de suministro requiere la gestión de riesgos.



- ❖ Rápida adopción de software de código abierto.
- ❖ Manipulación de hardware físico o de desastres naturales.

Caso: Las inundaciones en Tailandia crearon una escasez significativa en el mercado de unidades de discos duros, que costó millones de dólares en pérdidas a conocidos fabricantes de electrónica.

Los productos o servicios fabricados en cualquier lugar pueden contener vulnerabilidades que pueden presentar oportunidades para los compromisos relacionados con la cadena de suministro de las ICT.

Es importante considerar el riesgo de la cadena de suministro desde el desarrollo del sistema, para **incluir la investigación y el desarrollo (R&D) a través de la vida útil**, y en última instancia el retiro/eliminación de los productos.

RECUPERACIÓN DE DESASTRES Y PLANES DE CONTINUIDAD DEL NEGOCIO.

OBJETIVOS DE TIEMPO DE RECUPERACIÓN (RTO)

RTO => Cantidad de tiempo permitido para la recuperación de una función de negocios o un recurso después de que ocurra un desastre.

Costo actual de la pérdida es igual al costo de la recuperación.

OBJETIVO DE PUNTO DE RECUPERACIÓN

RPO => Pérdida de datos aceptable en caso de una interrupción de las operaciones. Indica el punto más temprano en el tiempo en el que es aceptable recuperar los datos.

Para asegurar un plan de gestión de incidentes o un plan de recuperación de desastre efectivo, el RTO y RPO deben estar estrechamente vinculados.

Un RTO corto puede ser difícil de lograr si hay una gran cantidad de datos para ser restaurados (RPO).

RECUPERACIÓN DE DESASTRES Y PLANES DE CONTINUIDAD DEL NEGOCIO.

Tipos de copias de seguridad:

Completo: Proporcionan una copia completa de todos los archivos, independientemente de si fue respaldada recientemente. -> **Método más lento pero más rápido para la restauración de datos.**

Incrementales: Copian todos los archivos que han cambiado desde que se hizo la última copia de seguridad. => **Método más rápido, pero más lento para la restauración de datos.**

Diferenciales: sólo copian los **archivos que han cambiado desde la última copia** de seguridad completa.

1. INTRODUCCIÓN Y VISIÓN GENERAL DE LA CIBERSEGURIDAD

2. CONCEPTOS DE LA CIBERSEGURIDAD

3. PRINCIPIOS DE ARQUITECTURA DE SEGURIDAD

4. SEGURIDAD DE REDES, SISTEMAS, APLICACIONES Y DATOS

5. RESPUESTA A INCIDENTES

6. IMPLICACIONES DE SEGURIDAD Y ADOPCIÓN DE LA TECNOLOGÍA

PANORAMA ACTUAL DE AMENAZAS

La ciberseguridad está cambiando constantemente a medida que se desarrollan nuevas tecnologías y los ciberataques se vuelven más sofisticados.

Las corporaciones se vuelven más dependientes de las tecnologías digitales, que son susceptibles de ser afectadas por ciber riesgos.

Informática en la nube (Cloud), las redes sociales y la informática en móviles están cambiando en la forma en que usan y comparten la información.

MOTIVACIONES DE LOS CIBER CRIMINALES:

- ☐ Beneficios financieros
- ☐ Propiedad Intelectual (espionaje)
- ☐ Política (activismo)



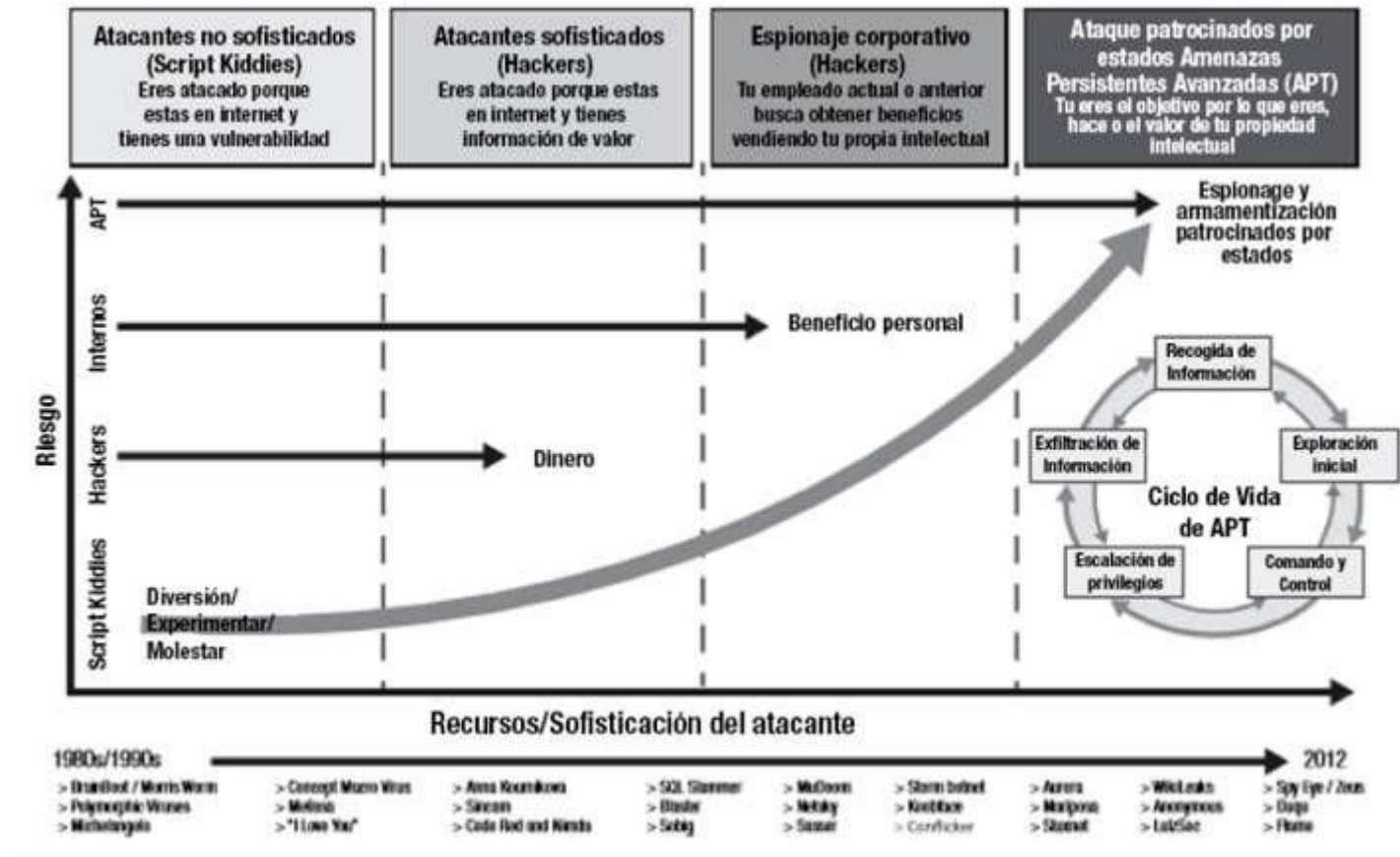
PANORAMA ACTUAL DE AMENAZAS

Tendencias

- ❑ Amenazas son más sofisticadas en cuanto a sus ataques y al uso de herramientas.
- ❑ Patrones de ataque se están dirigiendo a dispositivos móviles.
- ❑ (Ciber guerra). Naciones han adquirido la capacidad de infiltrarse en objetivos gubernamentales y privados.
- ❑ Grandes concentraciones de datos en la nube (Cloud) han pasado a convertirse en objetivos para posibles atacantes.
- ❑ Los atacantes pueden hacer mal uso de las redes sociales para obtener datos personales y generar desinformación.
- ❑ Big data (macro datos) propicia la posibilidad de brechas en los Big Data.

AMENAZAS PERSISTENTES AVANZADAS

Tipos de amenazas que requieren un grado de vigilancia.



DEFINIENDO LAS AMENAZAS PERSISTENTES AVANZADAS (APTS)

- ❑ Un APT es una **amenaza específica que está compuesta de varios vectores de ataque complejos** y que permanece oculta (sin ser detectada) durante un periodo de tiempo prolongado.
- ❑ Ataque **sofisticado, dirigido** a un objetivo específico que reaparece tras la víctima.
- ❑ **No es fácilmente desviado** por una respuesta defensiva determinada.

Ejemplo APT: Phishing de ingeniería social “spear phishing”: utiliza técnicas de ingeniería social para enmascararse, con el fin de obtener información importante, como la contraseña de la víctima.

CARACTERÍSTICAS

- ❖ **Bien documentados** — Investigan a fondo sus objetivos, planifican el uso de sus recursos y anticipan las posibles contramedidas.
- ❖ **Sofisticados** — Ataques APT: son diseñados habitualmente para explotar múltiples vulnerabilidades en un ataque único.
- ❖ **Persistentes** — Proyectos a largo plazo con enfoque en el reconocimiento. Si un ataque es bloqueado con éxito, los autores responden con nuevos ataques.

Figura 6.3: Tipos e Impactos de APT

Amenaza	Lo que busca	Impacto en el negocio
Agencias de inteligencia	Secretos políticos, de defensa o comerciales	La pérdida de secretos comerciales o, ventaja competitiva comercial
Grupos Criminales	Las transferencias de dinero, oportunidades de extorsión, información personal de identidad o cualquier secreto para su venta posterior potencial	La pérdida financiera, fugas de datos de clientes a gran escala o la pérdida de secretos comerciales
Grupos terroristas	Producción de terror generalizado a través de la muerte, destrucción y alteración	La pérdida de la producción y los servicios, las irregularidades del mercado de valores y el riesgo potencial para la vida humana
Grupos activistas	La información confidencial o interrupción de los servicios	Importantes fugas de datos o pérdida de servicio
Fuerzas armadas	Inteligencia o posicionamiento de apoyo a futuros ataques contra la infraestructura nacional crítica	Graves daños a las instalaciones en caso de un conflicto militar

FASES DE UN ATAQUE APT

ciclo de vida:

- Recolección de información.
- Seleccionar y estudiar sus objetivos.
- Planear el ataque.
- Recoger y analizar la información obtenida de una primera infiltración.

El atacante establece el comando y control, recogiendo la información del objetivo.

Información se transmite a la localización del atacante para ser diseminada o explotada.



TECNOLOGÍA MÓVIL-VULNERABILIDADES, AMENAZAS Y RIESGOS

Vulnerabilidad	Amenaza	Riesgo
La información viaja a través de redes inalámbricas que a menudo son menos seguras que las redes cableadas.	Forasteros maliciosos pueden hacer daño a la empresa.	Intercepción de información que resulta en una fuga de datos confidenciales, daño a la reputación de la empresa, adhesión comprometida con la regulación o acción legal.
La movilidad proporciona a los usuarios la oportunidad de abandonar los límites de la empresa, lo que elimina muchos controles de seguridad.	Los dispositivos móviles cruzan los límites y perímetros de red, llevando malware, y pueden traer este malware a la red empresarial.	La propagación de malware, puede dar lugar a la fuga de datos, corrupción de datos y la falta de disponibilidad de los datos necesarios; robo físico.
La tecnología Bluetooth (BT) hace que sea muy conveniente para muchos usuarios tener conversaciones con manos libres; sin embargo, a menudo se deja encendida y es entonces visible.	Los hackers pueden descubrir el dispositivo y entonces lanzar un ataque.	La corrupción de dispositivos, la pérdida de datos, intercepción de llamadas, posible exposición de información sensible.
Información sin cifrar se almacena en el dispositivo.	En el caso de que un forastero malicioso intercepte datos en tránsito o robe un dispositivo, o si el empleado pierde el dispositivo, los datos se pueden leer y utilizar.	La exposición de datos confidenciales, lo que resulta en daño a la empresa, clientes o empleados.

TECNOLOGÍA MÓVIL-VULNERABILIDADES, AMENAZAS Y RIESGOS

Perdida de datos puede afectar la productividad de los empleados.	Los dispositivos móviles se pueden perder o robar debido a su portabilidad. Los datos sobre estos dispositivos no siempre están respaldados.	Los trabajadores dependientes de dispositivos móviles no pueden trabajar en caso de rotura, pérdida o robo, y los datos que no están respaldados.
El dispositivo no tiene requisitos de autenticación aplicados.	Si el dispositivo se pierde o es robado, los extraños pueden acceder al dispositivo y a todos sus datos.	La exposición de datos, resulta en daño a los aspectos de responsabilidad y regulación empresarial.
La empresa no está gestionando el dispositivo.	Si no existe una estrategia de dispositivo móvil, los empleados pueden optar por llevar sus propios dispositivos, sin garantía. Mientras que estos dispositivos no pueden conectarse a la red privada virtual (VPN), pueden interactuar con mensajes de correo electrónico o almacenar documentos sensibles.	Fuga de datos, propagación de malware, pérdida de datos desconocida en caso de pérdida o robo del dispositivo.
El dispositivo permite la instalación de aplicaciones de terceros no verificadas/sin firma.	Las aplicaciones pueden llevar malware que propaga a los troyanos o virus. Las aplicaciones también pueden transformar el dispositivo en una pasarela para los extraños maliciosos para entrar en la red de la empresa.	Propagación de malware, fuga de datos, intrusión a la red de la empresa.

RIESGO ORGANIZATIVO

- ❖ Los dispositivos móviles se han introducido rápidamente en las empresas a todos los niveles.
- ❖ Programas como (**BYOD** del Inglés Bring Your Own Device). Muchos usuarios tienen acceso privilegiado que a menudo se replica en sus dispositivos móviles.
- ❖ El grupo de Cs y la alta dirección son usuarios que utilizan sus dispositivos móviles de forma frecuente. Cualquier compromiso exitoso de sus dispositivos puede causar un daño importante ciertamente.
- ❖ Complejidad y diversidad dispositivos móviles comunes: Representan un desafío, muchos dispositivos móviles están pensados para llevar al usuario a cometer errores humanos y problemas de seguridad.

Ejemplo: Seguimiento involuntario vía GPS.

Riesgo resultante: Falta de formación sobre el uso de los dispositivos móviles.

Figura 6.6: Monitoreo de actividad y Riesgo de Recuperación de Datos⁴⁸

Objetivo	Riesgo
Mensajería	Ataques genéricos de texto SMS , la transmisión de texto y contenido en enriquecido MMS
	La recuperación de contenidos de correo electrónico en línea y fuera de línea
	La inserción del comandos de servicio a través de mensajes de difusión celular SMS
	Ejecución de código arbitrario a través de SMS/MMS
	ML habilitado mensajes SMS o correo electrónico
	Reorientar o ataques de phishing por HTML habilitado en mensajes SMS o correo electrónico
Audio	Iniciación de llamada encubierta , grabación de llamadas
	Habilitar la grabación por el micrófono
Imágenes/Video	Recuperación de las fotografías y videos , por ejemplo, a través de piggybacking de la habitual funcionalidad de "compartir" en la mayoría de las aplicaciones móviles
	Tomar y compartir fotos o videos encubierto, incluyendo no dejar rastro de dicho material
Geolocalización	Monitoreo y recuperación de datos de posicionamiento GPS, incluyendo la fecha y hora
Datos estáticos	Recuperación de lista de contactos, calendario, tareas, notas
Historial	Monitoreo y recuperación de todos los archivos históricos en el dispositivo o en la tarjeta SIM (llamadas, SMS, navegación, información de entrada, contraseñas almacenadas, etc.)
Almacenamiento	Ataques genéricos en el dispositivo de almacenamiento (disco duro o disco de estado sólido [SSD]) y los datos replicados allí

SUPLANTACIÓN PÁGINA WEB / INTERFAZ DE USUARIO (UI)

Cuando la víctima suministra las credenciales de autenticación, estas son **transmitidas a un atacante conduciendo a ataques de suplantación** similares al phishing.

Ataques a nivel de proxy (phishing de credenciales) y a nivel de presentación (sitios web falsos presentados a través de la vista web móvil).

Debido al atractivo que tiene la información de pago y las credenciales de usuarios, es probable que los riesgos aumenten en un futuro. - Formjacking



FILTRACIÓN DE INFORMACIÓN SENSIBLE.

- Los dispositivos móviles normalmente almacenan grandes cantidades de **información sensible**.
- Una aplicación legítima puede tener **fallos en el uso del dispositivo**. Como resultado, la información y la autenticación de las credenciales pueden estar expuestas a terceros.
- Los **dispositivos móviles proporcionan una imagen bastante detallada de lo que sus usuarios hacen**, dónde están y sus preferencias.

Figura 6.8: Riesgo de Fuga de Datos Confidenciales⁵⁰

Tipo de Información	Riesgo
Identidad	Identidad de equipo móvil Internacional (IMEI), ID de fabricante del dispositivo, información de usuario personalizada
	Estadísticas de liberación de hardware/firmware y software, también revelar lo conocido
	Debilidades o exploits (Código para explotar debilidades) potenciales de día cero
Credenciales	Nombres de usuario y contraseñas, pulsaciones de teclado
	Tokens de autorización, certificados (S/MIME, PGP, etc.)
Archivos de localización	Coordenadas GPS, seguimiento de movimiento , inferencia de lugar/conducta
	Todos los archivos almacenados a nivel del sistema operativo/sistema de archivos

Los usuarios se encuentran en condiciones de trabajar desde cualquier lugar en cualquier momento. Los dispositivos inteligentes han permitido reemplazar los PCs y portátiles para muchas aplicaciones de empresa.

IMPACTO

- ☐ Hardware: Potencia de cálculo y el almacenamiento son equivalentes al hardware de PC.
- ☐ Nuevos servicios móviles han creado nuevos modelos de negocio.

BYOD

Muchos usuarios han creado la expectativa de conectar sus propias unidades para lograr productividad de una forma rápida y pragmática.

Desafío: Gestionar la seguridad del dispositivo frente a equipos desconocidos.

BYOD se está convirtiendo en un **importante factor de motivación laboral**. Los empleados no están dispuestos a aceptar restricciones tecnológicas.

Pros	Contras
• Cambia el coste al usuario • Sastisfacción del trabajador • Actualizaciones de hardware más frecuentes • Tecnología innovadora con las ultimas características y capacidades	• Pérdida de control de TI • Riesgos de seguridad conocidos o desconocidos • Política de Uso Aceptable más difícil de implementar • Cumplimiento y propiedad de la información no clara

LA NUBE Y LA COLABORACIÓN DIGITAL

De acuerdo a la NIST y la Cloud Security Alliance (CSA), **Cloud Computing** se define como un “modelo para permitir el acceso a la red bajo demanda a un conjunto compartido de recursos informáticos configurables que pueden ser aprovisionados y liberados con un mínimo esfuerzo de gestión o interacción del proveedor del servicio.”

Cloud computing ofrece a las empresas una forma de ahorrar en el gasto de capital asociado a los métodos tradicionales de gestionar las TI.

Plataformas

- Software como Servicio (**SaaS**).
- Plataforma como Servicio (**PaaS**).
- Infraestructura como Servicio (**IaaS**).

Cloud computing no deja de tener su propio conjunto de riesgos. Primero y más importante es la seguridad de la información que se confía a los proveedores de la nube.

RIESGO DL CLOUD COMPUTING

El NIST resalta los siguientes riesgos de seguridad de la infraestructura de la nube:

- ❑ **Pérdida de gobierno** — El cliente **cede cierto nivel de control** al proveedor de la nube; esto puede afectar a la seguridad a nivel de los SLAs.
- ❑ **Bloqueo** — **Dependencia a un proveedor** de la nube. Cambiar de un proveedor a otro puede dificultar la prestación del servicio.
- ❑ **Fallos en el aislamiento** — **Fallo en los mecanismos que separan el almacenamiento**, memoria, enrutamiento y la reputación entre los diferentes clientes.
- ❑ **Cumplimiento** — Migrar a la nube puede **crear riesgos** para obtener la certificación de la organización si el proveedor no proporciona prueba de cumplimiento.
- ❑ **Comprometer la interfaz de gestión** — **Acceder a la interfaz a través de Internet** facilita el acceso a los recursos.
- ❑ **Protección de datos** — Verificar procedimientos de **gestión de datos del proveedor de la nube**.
- ❑ **Eliminación de datos incompleta o insegura** — Múltiples contratos de arrendamiento y reutilización de los recursos de hardware incrementa el riesgo que **la información no sea eliminada adecuadamente**.
- ❑ **Infiltrado malicioso** — Un infiltrado malicioso puede causar **daño de alto grado**.

BENEFICIOS CLOUD COMPUTING

- **Impulso de mercado** —> Los proveedores de la nube tienen una motivación fuerte para **incrementar y mejorar sus prácticas de seguridad**.
- **Escalabilidad** —> Permite una **rápida reasignación de los recursos**, tales como filtrado, organización del tráfico, autenticación y cifrado y medidas defensivas.
- **Rentabilidad** —> La concentración de recursos proporciona perímetros físicos y controles de acceso físico **más baratos** y facilita la aplicación de muchos procesos de seguridad.
- **Actualización oportuna y eficaz** —> Las **actualizaciones pueden ser desplegadas rápidamente** a través de una plataforma homogénea.
- **Auditoría y evidencia** —> Proporciona **imágenes forenses de máquinas virtuales**, que resulta en menos tiempo de inactividad por las investigaciones forenses.



**Politécnico
Internacional**

Harol Hernan Torres Neuta
Cel: +57 3222469847